



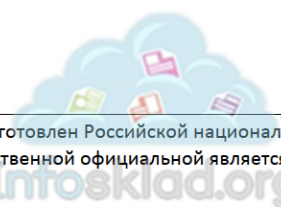
Концепция обеспечения безопасности пользователей SWIFT (версия 2019)

Программа безопасности пользователей

Подробное описание

В документе определяется комплекс обязательных и рекомендуемых элементов контроля безопасности для операционной среды пользователей SWIFT. Обязательные элементы контроля безопасности основаны на существующих правилах и обеспечивают базовый уровень безопасности для всего сообщества пользователей. Рекомендуемые элементы контроля – это передовой опыт, который SWIFT рекомендует внедрять в своей операционной среде каждому пользователю.

10 августа 2018 г.



Настоящий перевод был подготовлен Российской национальной ассоциацией СВИФТ.
Обращаем ваше внимание, что единственной официальной является англоязычная версия документа.

Скачивай платные курсы, тренинги и другие материалы - бесплатно!

Содержание

Введение	4
Обзор изменений	5
Основополагающие цели и принципы	7
Область применения элементов контроля безопасности	9
Типы архитектур.....	12
Структура элементов контроля безопасности	15
Соответствие элементам контроля безопасности	16
Сводная таблица по элементам контроля безопасности	17
Подробное описание элементов контроля безопасности	18
1. Ограничение доступа в интернет и защита наиболее важных систем от общей ИТ-среды	18
1.1. Обеспечение защиты среды SWIFT	18
1.2. Контроль за привилегированными учетными записями операционной системы	23
1.3А. Защита платформы виртуализации	25
2. Уменьшение количества потенциальных векторов атак и уязвимостей.....	26
2.1. Безопасность внутреннего потока данных.....	26
2.2. Обновления для системы безопасности.....	27
2.3. Повышение надежности системы.....	29
2.4А. Безопасность передачи данных из бэк-офиса	31
2.5А. Защита данных при передаче во внешнюю среду	32
2.6. Конфиденциальность и целостность сессии оператора.....	33
2.7. Сканирование на уязвимость системы	34
2.8А. Аутсорсинг критически важных видов деятельности	35
2.9А. Средства контроля транзакционного бизнеса	36
2.10А. Повышение надежности приложений	38
3. Обеспечение физической безопасности среды	40
3.1. Физическая защита	40
4. Предотвращение компрометации учетных данных.....	42
4.1. Политика паролей	42
4.2. Многофакторная аутентификация	44
5. Управление идентификационными данными и разграничение полномочий	46
5.1. Логический контроль доступа	46
5.2. Управление токенами	48
5.3А. Процесс проверки персонала	49
5.4. Физическое и логическое хранение паролей	50
6. Обнаружение аномальной активности в системах или журналах транзакций.....	51
6.1. Защита от вредоносных программ	51
6.2. Целостность программного обеспечения	53
6.3. Целостность базы данных.....	54
6.4. Ведение журнала операций и мониторинг	55
6.5А. Обнаружение вторжений	57
7. План реагирования на инциденты и информирования	58
7.1. Планирование реагирования на киберинциденты	58
7.2. Информирование и обучение в сфере безопасности	60
7.3А. Тест на проникновение.....	61
7.4А. Оценка рисков на основе сценариев.....	63

Приложение А. Сводная матрица по факторам риска	65
Приложение Б. Примеры зон безопасности для разных архитектур.....	67
Приложение В. Примеры сценариев угроз.....	70
Приложение Г. Словарь терминов.....	75
Приложение Д. Сопоставление с отраслевыми стандартами	79
Официальное уведомление.....	87

Введение

Кибератаки на компании финансового сектора становятся все более изощренными. Регулярность возникновения таких угроз подчеркивает важность сохранения бдительности и необходимость упреждающего реагирования в долгосрочной перспективе. Несмотря на то, что клиенты несут ответственность за защиту их собственной среды, SWIFT создал Программу безопасности пользователей (CSP) для поддержки своих клиентов в борьбе с киберпреступлениями. CSP устанавливает единый набор элементов контроля безопасности, предназначенных для того, чтобы помочь пользователям обеспечить защиту своих локальных сред и способствовать формированию более безопасной финансовой экосистемы.

Концепция обеспечения безопасности пользователей SWIFT описывает комплекс обязательных и рекомендуемых элементов контроля безопасности (далее – ЭК) для пользователей SWIFT. Обязательные ЭК обеспечивают базовый уровень безопасности для всего сообщества и должны быть внедрены всеми пользователями в их локальной инфраструктуре SWIFT. SWIFT решил определить приоритетность этих обязательных ЭК, чтобы установить реалистичную цель на ближайшую перспективу: существенное повышение уровня безопасности и снижение рисков. Рекомендуемые ЭК, основанные на передовом опыте, предлагаются к применению пользователям SWIFT. Со временем обязательные ЭК могут быть изменены в связи с эволюцией угроз, а некоторые рекомендуемые ЭК могут стать обязательными.

Все ЭК направлены на достижение трех главных целей: «обеспечивать безопасность среды», «знать и ограничивать доступ» и «обнаруживать и реагировать». ЭК были разработаны на основе анализа сведений о киберугрозах, проведенного SWIFT с участием отраслевых экспертов, и с учетом отзывов пользователей. Подразумевается, что эти ЭК соответствуют существующим стандартам информационной безопасности.

ЭК, описанные в этом документе, представляют собой общие, независимые от программного комплекса средства контроля. Они не должны рассматриваться как исчерпывающие или универсальные, не заменяют хорошо структурированную систему обеспечения безопасности и управления рисками, охватывающую всю сквозную цепочку транзакций, а также здравый смысл или соответствие новейшим лучшим видам практики.

С учетом меняющегося характера киберугроз эти ЭК будут регулярно оцениваться и по мере необходимости уточняться, расширяться и публиковаться в новой версии этого документа. Поэтому, пожалуйста, убедитесь в том, что вы всегда используете самую последнюю доступную версию этого документа, размещенную в Руководстве пользователя (SWIFT User Handbook).

Для обеспечения внедрения ЭК в SWIFT разработан процесс аттестации и соблюдения требований, в рамках которого потребуются, чтобы пользователи самостоятельно подтверждали соответствие обязательным и, по желанию, рекомендуемым ЭК. Пользователям будет предложено предоставлять информацию о статусе самоаттестации для ее размещения в специализированной папке аттестации по требованиям безопасности в KYC Registry. Все пользователи должны самостоятельно подтвердить соответствие обязательным ЭК, изложенным в конкретной версии документа, не позднее конца года, указанного в версии документа (например, не позднее конца 2019 года по версии 2019). После этого пользователям необходимо будет предоставлять результаты аттестации на ежегодной основе.

Каждый пользователь сохраняет права доступа к собственным данным, а также сможет предоставлять доступ к ним своим контрагентам, позволяя просматривать свой статус самоаттестации. Данная мера будет способствовать обеспечению прозрачности и создаст стимулы для повышения безопасности, позволяя другим пользователям сети принимать основанные на оценке рисков решения, касающиеся их деловых отношений. Для получения дополнительной информации о процедуре самоаттестации и соблюдения требований обратитесь к самой последней версии документа «*Политика обеспечения безопасности пользователей SWIFT*» (SWIFT Customer Security Controls Policy), которую можно найти в Руководстве пользователя (SWIFT User Handbook).

Программа безопасности пользователей (CSP) разработана для совместной работы SWIFT и ее пользователей в целях повышения общей безопасности финансовой экосистемы. Поэтому все пользователи должны внимательно ознакомиться с ЭК, изложенными в этом документе, и подготовиться к их внедрению в рамках своей организации.

Обзор изменений

В Концепции обеспечения безопасности пользователей SWIFT версии 2019 года три рекомендуемых ЭК из предыдущей версии - 2.6, 2.7 и 5.4 - стали обязательными и добавлены два новых рекомендуемых ЭК - 1.3А и 2.10А. Этот документ также содержит некоторые дополнительные методические рекомендации и дает, где это применимо, рекомендации по внедрению или альтернативные решения.

В следующей таблице представлены наиболее значительные изменения содержания этого документа по сравнению с предыдущей версией. Таблица не включает редакционные изменения, которые SWIFT делает для улучшения удобства использования и понимания этого документа.

ЭК или раздел	Изменения
Ужесточение требований - рекомендуемые ЭК, переведенные в категорию обязательных	
2.6А Конфиденциальность и целостность сессии оператора	Обязательное использование защищенных протоколов для пользовательских интерактивных сессий
2.7А Сканирование на уязвимость системы	Обязательное - не реже одного раза в год сканирование и принятие соответствующих мер
5.4А Физическое и логическое хранение паролей	Обязательное безопасное хранение учетных данных
Ужесточение требований - новые рекомендуемые ЭК	
1.3А Защита платформы виртуализации	Добавлено руководство по применению
2.10А Повышение надежности приложений	Добавлено руководство по применению для SWIFT сертифицированных интерфейсов
Дополнительные методические рекомендации	
2.4А Безопасность передачи данных из бэк-офиса	Дан список более стандартных решений: асимметричные ключи, AES GCM, - чтобы облегчить внедрение в бэк-офисные потоки данных
4.1 Политика паролей	Добавлены рекомендации относительно персональных токенов или PIN-политики на мобильных устройствах
5.2 Управление токенами	Добавлены рекомендации относительно устройства ввода PIN-кода (PED) аппаратного модуля системы безопасности (HSM)
7.3А Тест на проникновение	Дополнительные рекомендации (проводить тестирование каждые 2 года независимым персоналом - силами внутренней "красной команды" или с привлечением внешних ресурсов) до тех пор, пока ЭК не станет обязательным в будущих версиях документа
Ближе к реальности - действенные альтернативные решения	
1.1 Обеспечение защиты среды SWIFT	Условное использование промежуточного сервера вне зоны безопасности SWIFT
2.3 Повышение надежности системы	Поддержание долгосрочного повышения надежности путем регулярной проверки или повторного применения параметров
4.2 Многофакторная аутентификация	Обращение к стандартным принципам и типовым решениям, таким, как действующий ограниченный по времени одноразовый пароль (Time based One

ЭК или раздел	Изменения
	Time Password - TOTP), Персональный Токен или базовый коннектор SAML для внутреннего поставщика идентификации (Identity Provider - IdP) с многофакторной проверкой подлинности
Уточнения по существующим ЭК	
Область применения элементов контроля безопасности	Предусмотрены в соответствующих случаях компоненты Alliance Instant и DirectLink
Типы архитектур	В архитектуру A1 включена также конфигурация, согласно которой пользователь работает только с коммуникационным интерфейсом, без необходимости размещения полной архитектуры на стороне клиента
1.1 Обеспечение защиты среды SWIFT	Уточнено понятие специализированного файервола
2.2 Обновления для системы безопасности	Добавлено требование о проведении проверки целостности системы перед применением обновлений безопасности
2.3 Повышение надежности системы	SWIFT HSM выведен за рамки данного ЭК
3.1 Физическая защита	Alliance Connect VPN box в целом находится за рамками данного ЭК, но ожидается, что он будет находиться в среде с соответствующими физическими ЭК
4.2 Многофакторная аутентификация (MFA)	Уточнено, в каких случаях должна применяться MFA
6.1 Защита от вредоносных программ	Указаны дополнительные входные данные, подлежащие сканированию
6.3 Целостность базы данных	Уточнено, что этот ЭК находится вне области применения для архитектуры типа A3
7.1 Планирование реагирования на киберинциденты	Приведена дополнительная информация, касающаяся SWIFT ISAC Recovery Roadmap (Дорожная карта по восстановлению на портале SWIFT ISAC)
7.4A Оценка рисков на основе сценариев	Даны дополнительная информация и практические рекомендации для достижения целей внедрения ЭК

Основополагающие цели и принципы

Цели и принципы

Элементы контроля безопасности (ЭК) базируются на трех основных целях, подкрепленных восемью принципами безопасности. Цели – это самый высокий уровень структуры безопасности в локальной среде пользователя. Связанные с ними принципы конкретизируют наиболее приоритетные направления деятельности в рамках каждой цели. На рисунке ниже приведены цели и соответствующие им принципы:



Рисунок 1. основополагающие цели и принципы

Эти цели и принципы лежат в основе 29 элементов ЭК (19 обязательных и 10 рекомендуемых ЭК), подробно изложенных в настоящем документе. ЭК предназначены для того, чтобы помочь уменьшить определенные риски кибербезопасности, с которыми сталкиваются пользователи SWIFT в сфере киберугроз. В рамках каждого ЭК SWIFT документально зафиксировал наиболее распространенные факторы риска, а сами ЭК разрабатываются, чтобы помочь их минимизировать. Устранение этих рисков направлено на предотвращение или сведение к минимуму нежелательных и потенциально вредоносных последствий для бизнеса, таких как:

- несанкционированная отправка или изменение финансовых транзакций;
- обработка измененных или несанкционированных входящих транзакций SWIFT;
- ведение бизнеса с неавторизованным контрагентом;
- нарушение конфиденциальности (бизнес-данных, компьютерных систем или сведений об операторе);
- нарушение целостности (данных о бизнесе, компьютерных систем или сведений об операторе).

В конечном счете эти последствия представляют риски на уровне предприятий, включая:

- финансовый риск;
- юридический риск;
- регуляторный риск;
- репутационный риск.

Интеграция с системами управления безопасностью и управления рисками

SWIFT призывает пользователей рассматривать управление киберрисками в самом широком смысле, в том числе за пределами области инфраструктуры пользователей SWIFT и ЭК SWIFT. Для наиболее эффективного управления рисками пользователи не должны рассматривать внедрение данных ЭК ни как разовое или единичное, ни как охватывающее все сферы безопасности мероприятие. Пользователям следует скорее включить ЭК SWIFT в текущую программу управления кибербезопасностью и рисками в

рамках своей организации, которая принимает во внимание здравый смысл и новейшие передовые практики и учитывает специфическую для пользователя инфраструктуру и конфигурации. В результате пользователи могут широко применять и извлекать выгоду из существующих политик, процедур и ЭК, которые были созданы для управления другими областями киберриска.

Комплексный подход к киберриску будет наиболее эффективным средством предотвращения риска на уровне предприятий, что позволит повысить общую безопасность каждой отдельной организации и финансового сообщества в целом.

Кроме того, пользователи должны иметь надлежащий уровень ответственности и контроля за своей деятельностью по управлению киберрисками. Как правило, важную роль в этом вопросе играет главный специалист / директор по информационной безопасности, определяя приоритеты программы безопасности и запрашивая соответствующую поддержку и рекомендации со стороны совета директоров.

Область применения элементов контроля безопасности

Элементы контроля безопасности (ЭК) в данном документе охватывают определенный набор компонентов в локальной среде пользователя (рис. 2).



Рисунок 2. Область применения элементов контроля безопасности

ЭК применяются к следующим входящим в область применения компонентам:

- **Уровень обмена данными** – поток данных между бэк-офисом (или ПО промежуточного уровня) и локальной инфраструктурой SWIFT.
- **Локальная инфраструктура SWIFT** – набор специфических компонентов SWIFT, управляемых пользователями или предназначенных для пользователей, включая приложения, сетевые компоненты, токены и другие съемные носители, а также поддерживающее аппаратное обеспечение. Примерами настройки локальной инфраструктуры SWIFT и компонентов в зависимости от типа пользовательской [архитектуры](#) являются:
 - **Зона безопасности** – сегментированная зона, отделяющая системы, связанные со SWIFT, от остальной территории (подробнее см. ЭК 1.1). Эта зона может расширяться за пределы локальной SWIFT-инфраструктуры и может включать в себя системы, не связанные со SWIFT.
 - **Интерфейс обмена сообщениями** – интерфейсное программное обеспечение, поддерживающее использование сервисов обмена сообщениями SWIFT (FIN, InterAct и FileAct) и SWIFTNet Instant. Это программное обеспечение предоставляет пользователям возможность подключать эти бизнес-приложения к сервисам обмена сообщениями SWIFT и, как правило, подключается непосредственно к коммуникационному интерфейсу. Интерфейсы обмена сообщениями предоставляются SWIFT (например, Alliance Access и Alliance Messaging Hub или Alliance Messaging Hub Instant) и сертифицированными сторонними разработчиками.
 - **Коммуникационный интерфейс** – программное обеспечение для передачи данных, обеспечивающее связь между сетью SWIFTNet и программным обеспечением для обмена сообщениями. Коммуникационные интерфейсы обеспечивают централизованную, автоматизированную и высокопроизводительную интеграцию с различными внутренними финансовыми приложениями и интерфейсами конкретных сервисов. Интерфейсы связи предоставляются SWIFT (например, Alliance Gateway или Alliance Gateway Instant) и сертифицированными сторонними разработчиками.

- **SWIFTNet Link (SNL)** – обязательный программный продукт SNL для доступа к службам обмена сообщениями через безопасную IP-сеть. Этот документ ссылается на SNL, который является частью области применения коммуникационного интерфейса.
- **Коннектор** – локальное программное обеспечение, предназначенное для упрощения взаимодействия с интерфейсом обмена сообщениями или коммуникационным интерфейсом, или и с тем и с другим. При использовании коннектора компоненты интерфейса предлагаются поставщиком услуг (например, сервис-бюро, инфраструктурой хабов или SWIFT). Alliance Lite2 AutoClient, DirectLink, решения для передачи файлов и аналогичные продукты считаются коннекторными решениями.
- Модули аппаратной защиты SWIFT, подключенные токены и смарт-карты.
- Файерволы, маршрутизаторы и пр., находящиеся внутри или вокруг инфраструктуры SWIFT (выделенные или совместно используемые).
- **Графический интерфейс пользователя (GUI)** - программное обеспечение, которое формирует графический интерфейс для пользователя (например, Alliance Web Platform Server-Embedded и эквивалентные продукты).
- **Операторы** – отдельные конечные пользователи и администраторы, которые непосредственно взаимодействуют с локальной инфраструктурой SWIFT на уровне приложения или операционной системы.
- **ПК оператора** – устройство конечного пользователя или администратора (как правило, это настольный компьютер или ноутбук), используемое для выполнения своих обязанностей (использование, эксплуатация или поддержка) локальной инфраструктуры SWIFT.
 - Этот компонент может ссылаться на промежуточный сервер, а не на персональное устройство оператора, если применяется такая архитектура.
 - Термины, "ПК оператора общего назначения" и "выделенный ПК оператора" определяются следующим образом:
ПК оператора общего назначения размещается в общекорпоративной ИТ-среде и используется для ежедневных рабочих операций, включая доступ к локальной инфраструктуре SWIFT.
Выделенный ПК оператора размещается в зоне безопасности и предназначен для взаимодействия с компонентами зоны безопасности (иногда также именуется «операционная консоль»).

Когда термин используется без уточнения – ПК оператора – то подразумеваются оба варианта: как общего назначения, так и выделенный ПК оператора.

Следующие компоненты находятся вне области применения:

- **Пользовательский бэк-офис и промежуточное ПО** – системы, отвечающие за бизнес-логику, генерацию транзакций и другие действия, происходящие до передачи в локальную инфраструктуру SWIFT. Например, внедренные в бэк-офис системы, такие как SAP и система учета (general ledger), не входят в область применения. Установленное промежуточное ПО, такое как IBM® MQ, как правило, не входит в область применения, но должно предусматривать соответствие элементам контроля, необходимым для защиты обмена данными с локальной инфраструктурой SWIFT (например, шифрование данных при передаче, аутентификация источника или целостность данных как при передаче, так и при управлении, в соответствии со специализированным компонентом SWIFT, определенным выше), когда не существует других ЭК на уровне сообщения или самих данных.
- **Общая корпоративная ИТ-среда** – общая ИТ-инфраструктура, используемая для поддержки целой организации (например, ПК общего назначения, почтовый сервер, сервисы каталогов и т. д.).

Подключения к сети SWIFT, предоставляемые партнерами SWIFT, интернет-соединение с сетью SWIFT, а также Alliance Connect VPN box, удаленно управляемые SWIFT, также выходят за рамки области применения. Однако, ожидается, что Alliance Connect VPN box будет находиться в среде с соответствующими физическими ЭК в соответствии с п.3.1 (Физическая защита).

Хотя это не является обязательным для целей процесса аттестации, ЭК отражают передовой опыт в области обеспечения безопасности, и поэтому целесообразно внедрять

их за пределами области применения в более широкую, сквозную цепочку транзакций.

Типы архитектур

Каждый пользователь должен установить, какой из четырех типов архитектуры (рис. 3–6) наиболее близок к их собственной, чтобы определить, какие компоненты входят в область применения. В зависимости от типа архитектуры некоторые элементы контроля безопасности (ЭК) могут или не могут быть применимы.

Ниже приведены четыре базовых типа архитектуры:

- ### Архитектура A1. Пользователи с коммуникационным интерфейсом

Коммуникационный интерфейс принадлежит пользовательской среде и находится внутри нее. Этот тип архитектуры также включает размещенные решения, в которых пользователь имеет право владения (имеет лицензию) для своей работы с коммуникационным интерфейсом, или для работы других пользователей (от имени другого пользователя /других пользователей).

Случай, когда и интерфейс обмена сообщениями, и коммуникационный интерфейс (полное размещение) находится внутри пользовательской среды, показан на рисунке ниже.

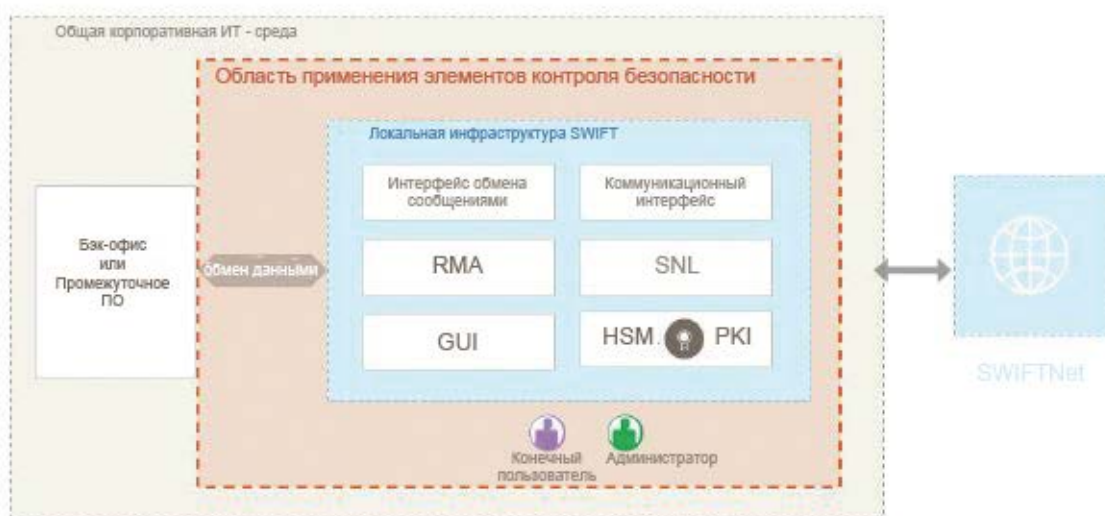


Рисунок 3. Архитектура A1. Полное размещение на стороне клиента

Конфигурация, при которой пользователь не взаимодействует с интерфейсом обмена сообщениями или не владеет им, но взаимодействует / владеет коммуникационным интерфейсом (как показано на рисунке ниже), также относится к архитектуре A1.

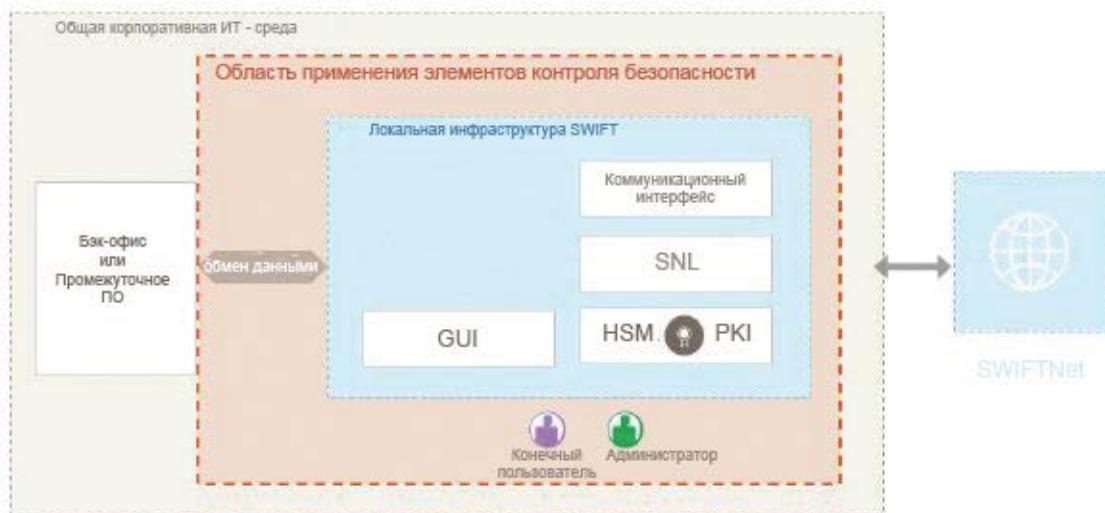


Рисунок 3б. Архитектура A1 - Коммуникационный интерфейс на стороне клиента

- **Архитектура A2. Частичное размещение на стороне клиента (рис. 4) – без коммуникационного интерфейса**

Интерфейс обмена сообщениями находится внутри пользовательской среды, но поставщик услуг (например, сервис-бюро, SWIFT Alliance Remote Gateway или групповой хаб) владеет лицензией и управляет коммуникационным интерфейсом. Этот тип архитектуры также включает размещенные решения интерфейса обмена сообщениями, где у пользователя есть лицензия на интерфейс обмена сообщениями.

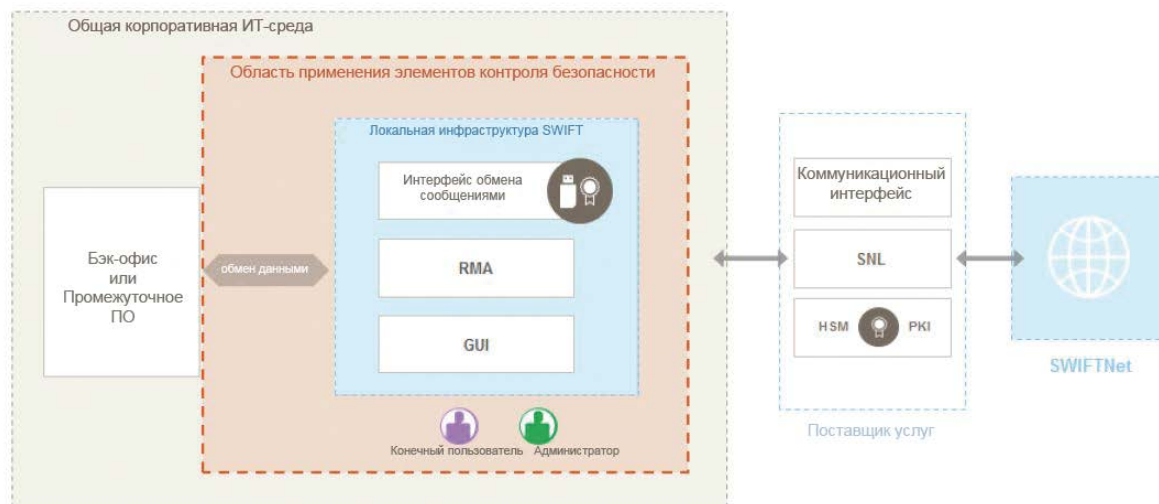


Рисунок 4. Архитектура A2. Частичное размещение на стороне клиента

- **Архитектура A3. С использованием коннектора (рис. 5)**

Программный комплекс (например, Alliance Lite2 AutoClient, Direct Link или решения для передачи файлов – file transfer solutions) используется внутри пользовательской среды для упрощения взаимодействия типа «приложение – приложение» с интерфейсом поставщика услуг (например, сервис-бюро, Alliance Lite2, групповой хаб). При необходимости эту настройку можно использовать в сочетании с GUI-решением – графическим интерфейсом пользователя (взаимодействие типа «пользователь – приложение»).

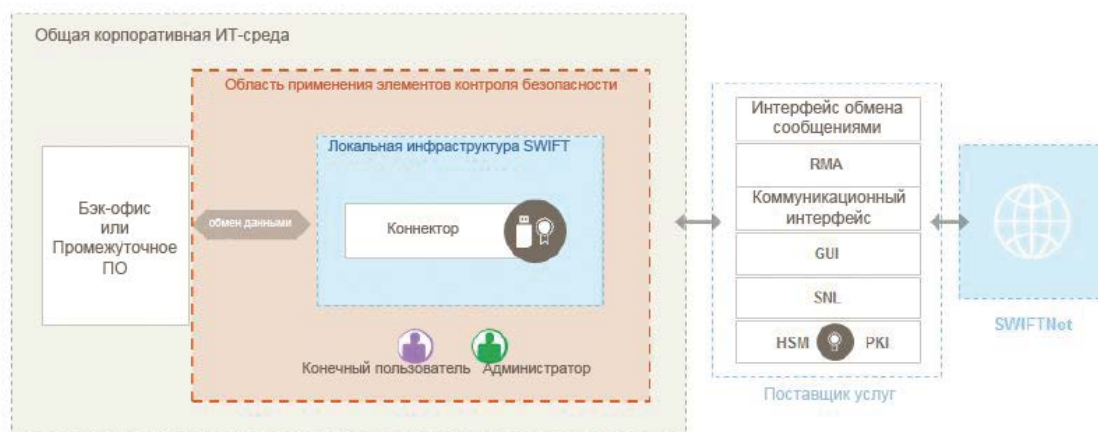


Рисунок 5. Архитектура A3. С использованием коннектора

- **Архитектура В. Без собственной инфраструктуры (рис. 6)**

В пользовательской среде не используется компонент инфраструктуры, зависящий от SWIFT.

Этот тип архитектуры предусматривает два варианта установки:

- Пользователи получают доступ к сервисам SWIFT только через графический

интерфейс приложения у поставщика услуг (взаимодействие типа «пользователь – приложение»). ПК или устройство, используемое такими пользователями для этих целей, следует рассматривать как ПК оператора (общего назначения), который должен быть защищен соответствующим образом.

- Пользовательские приложения бэк-офиса напрямую взаимодействуют с поставщиком услуг (взаимодействие типа «приложение – приложение»), используя промежуточное ПО (например, IBM® MQ или подобное) или API-интерфейсы поставщика услуг. Отнесение этого варианта установки к архитектуре типа В согласуется с областью применения элементов контроля безопасности (ЭК), которые исключают пользователя бэк-офиса и промежуточное ПО. Тем не менее, SWIFT настоятельно рекомендует внедрять ЭК архитектуры типа А3 в это промежуточное ПО и API-интерфейсы.

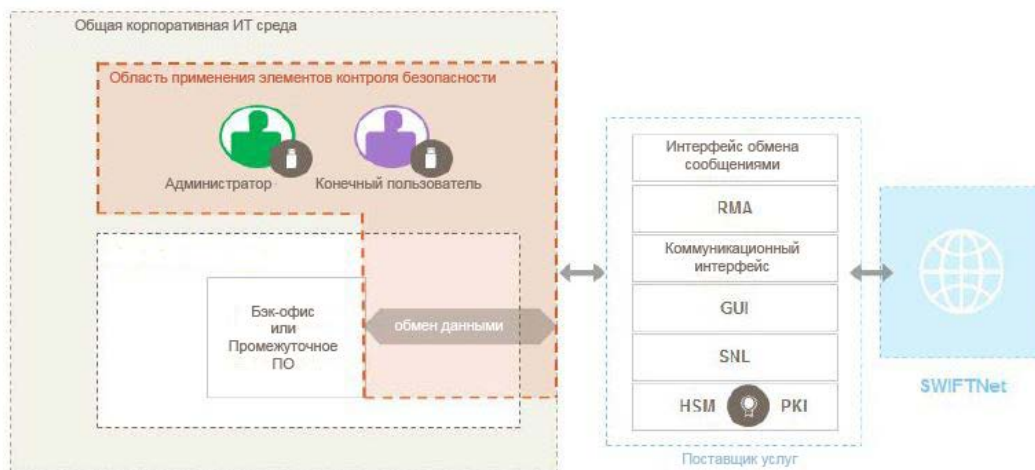


Рисунок 6. Архитектура В. Без собственной инфраструктуры

ЭК, применяемые для архитектур А1, А2 и А3, идентичны. Поэтому для этих архитектур на следующих страницах документа используется единое обозначение – «А». Меньшее количество ЭК безопасности применяется к пользователям, использующим тип архитектуры «В».

Структура элементов контроля безопасности

Описание каждого элемента контроля безопасности (ЭК) в этом документе состоит из трех блоков: общая информация об ЭК, определение ЭК и руководство по применению, как описано ниже.

Общая информация об ЭК

- **Номер и заголовок ЭК:** каждый ЭК имеет уникальный номер и заголовок. Если в номере ЭК присутствует буква «А», это означает, что данный ЭК «Рекомендуемый».
- **Тип ЭК:** определяет ЭК как «Обязательный» или «Рекомендуемый». Пользователи должны реализовывать все обязательные ЭК, применимые к ним с учетом используемого типа архитектуры. Рекомендуемые ЭК учитывают передовой опыт в области обеспечения безопасности и крайне желательны для реализации.
- **Применимость к типам архитектуры:** ЭК применяются либо к пользователям с архитектурой только типа А, либо к обоим типам А и В. Пользователи с архитектурой типа В не обязаны следовать ЭК, применяемым только к типу А.

Определение ЭК

- **Цель ЭК:** определяет цель в области обеспечения безопасности, которая должна быть достигнута независимо от метода ее реализации.
- **Компоненты, входящие в область применения:** специфические компоненты, связанные со SWIFT, на которые распространяется данный конкретный ЭК. (См. также [Область применения ЭК](#)).
- **Факторы риска:** подробные сведения о конкретных рисках, рассматриваемые данным ЭК. Полная матрица рисков приведена в [Приложении А](#). Сводная матрица по факторам риска.

Руководство по применению

- **Суть ЭК:** предлагаемые средства, с помощью которых может быть выполнена Цель ЭК.
- **Контекст ЭК:** дополнительная вводная справочная информация об этом ЭК.
- **Рекомендации по внедрению:** сформулированный компанией SWIFT метод реализации ЭК.

Внимание! Пользователи должны самостоятельно подтвердить соответствие всем целям обязательных ЭК. Дополнительная информация о вариантах реализации для обеспечения соответствия описана в следующем разделе.

Соответствие элементам контроля безопасности

Для того, чтобы соответствовать элементу контроля безопасности (ЭК), пользователи должны внедрить решение, которое обеспечивает достижение заявленной цели ЭК, учитывает факторы риска и охватывает описанную в документе область применения.

Пользователи могут сделать это одним из следующих способов:

1. Внедрение решения с использованием руководства по применению от SWIFT, приведенного в этом документе.
2. Внедрение альтернативного решения по отношению к сформулированному SWIFT руководству по применению, которое в равной степени обеспечит достижение цели ЭК с учетом связанных с ним рисков.

SWIFT допускает, что некоторые пользователи могут выбрать внедрение альтернативного решения. Если пользователь решает реализовать альтернативное решение, которое значительно отличается от сформулированного SWIFT, то при разработке решения пользователь должен учитывать следующее:

- a. Область применения: распространяется ли решение на входящие в состав ЭК компоненты, входящие в область применения?
- b. Факторы риска: снижает ли это решение документированные риски? (См. [Приложение А](#). Сводная матрица по факторам риска для матрицы рисков.)
- c. Эффективность: является ли решение эффективным на практике? (Например, принципы и правила, которые задокументированы, но не введены в действие или не соблюдаются, вряд ли будут эффективными.)

Пользователи в конечном итоге ответственны за оценку пригодности разработанного SWIFT руководства по применению или за определение того, хотят ли они принять альтернативные решения для внедрения. Раздел «Руководство по применению» не следует рассматривать как «чек-лист аудита», поскольку реализация этого руководства у каждого пользователя может отличаться. Таким образом, пользователи должны оценить, какие элементы руководства являются релевантными с учетом их специфической среды для достижения цели ЭК.

Ожидается, что только некоторые пользователи – как правило, крупные или сложно организованные – рассмотрят альтернативные маршруты внедрения для одного или нескольких ЭК. В любом случае пользователи несут ответственность за оценку собственного соблюдения обязательных ЭК и самостоятельное подтверждение соответствия независимо от внедренного решения.



Сводная таблица по элементам контроля безопасности

В следующей таблице представлен обзор всех обязательных и рекомендуемых элементов контроля безопасности (ЭК), структурированных в соответствии с принципом, который они поддерживают, и с указанием типа архитектуры, к которому они относятся. Помимо этого, таблица определяет соответствие ЭК типу архитектуры. В этом документе у рекомендуемых ЭК буква «А» присутствует после контрольного номера (например, «2.4А»), в таблице ниже они выделены серым фоном.

Обязательные и рекомендуемые элементы контроля	Тип архитектуры	
	А	В
1. Ограничение доступа в Интернет и защита наиболее важных систем от общей ИТ-среды		
1.1. Обеспечение защиты среды SWIFT	•	
1.2. Контроль за привилегированными учетными записями операционной системы	•	
1.3А. Защита платформы виртуализации	•	
2. Уменьшение количества потенциальных векторов атак и уязвимостей		
2.1. Безопасность внутреннего потока данных	•	
2.2. Обновления для системы безопасности	•	•
2.3. Повышение надежности системы	•	•
2.4А. Безопасность передачи данных из бэк-офиса	•	•
2.5А. Защита данных при передаче во внешнюю среду	•	
2.6. Конфиденциальность и целостность сессии оператора	•	•
2.7. Сканирование на уязвимость системы	•	•
2.8А. Аутсорсинг критически важных видов деятельности	•	•
2.9А. Средства контроля транзакционного бизнеса	•	•
2.10А. Повышение надежности приложений	•	
3. Обеспечение физической безопасности среды		
3.1. Физическая защита	•	•
4. Предотвращение компрометации учетных данных		
4.1. Политика паролей	•	•
4.2. Многофакторная аутентификация	•	•
5. Управление идентификационными данными и разграничение полномочий		
5.1. Логический контроль доступа	•	•
5.2. Управление токенами	•	•
5.3А. Процесс проверки персонала	•	•
5.4. Физическое и логическое хранение паролей	•	•
6. Обнаружение аномальной активности в системах или журналах транзакций		
6.1. Защита от вредоносных программ	•	•
6.2. Целостность программного обеспечения	•	
6.3. Целостность базы данных	•	
6.4. Ведение журнала операций и мониторинг	•	•
6.5А. Обнаружение вторжений	•	
7. План реагирования на инциденты и информирования		
7.1. Планирование реагирования на киберинциденты	•	•
7.2. Информирование и обучение в сфере безопасности	•	•
7.3А. Тест на проникновение	•	•
7.4А. Оценка рисков на основе сценариев	•	•

Тип ЭК: обязательный	Применяется к архитектуре:	A	B
Цель ЭК. Обеспечить защиту пользовательской локальной инфраструктуры SWIFT от потенциально скомпрометированных элементов общей ИТ-среды и внешней среды. Компоненты, входящие в область применения - Интерфейс обмена сообщениями. - Коммуникационный интерфейс. - Графический интерфейс. - SWIFTNet Link. - Аппаратный модуль системы безопасности (HSM). - Коннектор. - Промежуточный сервер. - Выделенные ПК оператора и ПК оператора общего назначения. Факторы риска - Компрометация системы аутентификации организации. - Компрометация учетных данных пользователя. - Воспроизведение учетных данных. - Незащищенность от интернет-атак. - Несанкционированный доступ. Руководство по применению Суть ЭК Изолированная зона безопасности защищает пользовательскую инфраструктуру SWIFT от компрометации и атак на более широкие корпоративные и внешние среды. Контекст ЭК Сегментация между локальной инфраструктурой SWIFT пользователя и его более крупной корпоративной сетью уменьшает количество потенциальных векторов атак и показывает, что является эффективным средством защиты от кибератак, которые, как правило, связаны с компрометацией общей корпоративной ИТ-среды. Эффективная сегментация будет включать в себя разделение на уровне сети, ограничения доступа и ограничения возможностей подключения. Рекомендации по внедрению а. Общие подходы к реализации разграничения среды - Внедрить «зону безопасности», чтобы отделить и защитить локальную инфраструктуру SWIFT от компрометации систем и сервисов, расположенных за пределами этой зоны. - В максимально возможной степени пароли и другие аутентификаторы, используемые в зоне безопасности (особенно для привилегированных учетных записей), не сохраняются и не используются ни в какой форме (хешированной, зашифрованной или в форме простого текста) в системах за пределами зоны безопасности. Данный пункт не относится к зашифрованным резервным копиям. Если система сервисов аутентификации находится за пределами зоны безопасности SWIFT:			

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
	- в том числе если система располагается в другой существующей зоне безопасности, в которой применяются аналогичные ЭК - или система используется только для фильтрации подключений к компонентам инфраструктуры SWIFT (контролируя затем подключения на границе зоны безопасности). В этом случае логический доступ к компонентам инфраструктуры SWIFT обеспечивается другими механизмами аутентификации, находящимися в зоне безопасности (другим механизмом управления идентификацией и доступом пользователей (IAM) или самим компонентом обеспечения доступа).		
	• Зона безопасности определяется исходя из каждой пользовательской среды, включая возможное повторное использование существующих зон безопасности (например, защищенная «производственная среда», «бэк-офисная среда» или «зона платежных систем»), в которую может быть включена локальная инфраструктура SWIFT. • Все компоненты в зоне безопасности защищены до такого же или эквивалентного уровня безопасности, контроля доступа, доверия и могут свободно взаимодействовать в пределах зоны. Пользователи могут рассмотреть возможность внедрения дополнительных разграничений между компонентами зоны безопасности. • Приложение Б. Примеры зон безопасности для разных архитектур содержат наглядные схемы архитектур, демонстрирующие примеры многочисленных способов, с помощью которых может быть спроектирована зона безопасности.		
б. Область применения зоны безопасности • Зона безопасности содержит все компоненты локальной инфраструктуры SWIFT, но не ограничивается ими. Она включает в себя: интерфейс обмена сообщениями, коммуникационный интерфейс, графический интерфейс на базе браузера, SWIFTNet Link, аппаратный модуль системы безопасности (HSM), коннектор, промежуточный сервер (см. подробности ниже) и любые применимые ПК оператора, предназначенные исключительно для работы или администрирования локальной инфраструктуры SWIFT. - ПК оператора общего назначения не включены в зону безопасности. - Выделенные ПК оператора с установленным программным обеспечением, связанным со SWIFT (то есть «толстый клиент» – рабочее место на основе ПК с программным обеспечением, включающим в себя графический интерфейс пользователя – GUI) находятся в зоне безопасности, или программное обеспечение устанавливается только на промежуточном сервере, доступ к которому получают ПК оператора общего назначения за пределами зоны безопасности. - Системы бэк-офиса и промежуточного ПО (например, приложения IBM® MQ) необязательно включаются в зону безопасности, но могут быть рассмотрены для их включения в зависимости от выбранного размера и области применения зоны безопасности. - Тестовые системы преимущественно полностью изолированы от производственных систем (включая отдельные модули HSM) и сконфигурированы так, чтобы поддерживать только тестовый трафик (например, только с использованием «облегченных» сертификатов и только для настройки тестовых логических терминалов). Если они не полностью изолированы, эти системы должны поддерживаться на том же уровне безопасности, что и производственные системы. Системы разработки не находятся в зоне безопасности и не подключены к сети SWIFT. - Alliance Connect VPN box находится в защищенной среде с соответствующими физическими ЭК в соответствии с п.3.1 (Физическая защита). • Размер и область применения зоны безопасности определяются наиболее подходящим для среды пользователя способом. Варианты могут включать, но не ограничиваются следующим: - Зона безопасности, предназначенная только для локальной инфраструктуры SWIFT. - Расширение существующей области безопасности (например, безопасная «производственная среда» или «зона платежных систем»), в которую может быть включена локальная инфраструктура SWIFT. Размер и область применения этой зоны могут значительно различаться в зависимости от существующей среды. • Программное обеспечение, системы и сервисы в зоне безопасности оцениваются по мере необходимости и удаляются из зоны, если они не поддерживают операции или безопасность зоны. (Например, оценка необходимости доступа к электронной почте.) • Все интерфейсы – интерфейс обмена сообщениями (Alliance Access и ему подобные) и коммуникационный интерфейс (Alliance Gateway и ему подобные) – внутри зоны безопасности сертифицированы SWIFT. Список сертифицированных интерфейсов поддерживается и публикуется SWIFT на swift.com.			

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
с. Защита зоны безопасности с.1 Защита границ - Файерволы с отслеживанием состояния на транспортном уровне используются для создания логического разделения на границе зоны безопасности. - Файерволы транспортного уровня, создающие границу зоны безопасности, должны быть физически или виртуально предназначены для защиты зоны безопасности. В случае, если файервол совместно используется для разделения других зон, должны быть предприняты меры для обеспечения того, чтобы компрометация файервола не оказала влияния на защиту зоны безопасности (такие как развертывание различных виртуальных экземпляров файервола, с выделением одного для зоны безопасности; формальная оценка рисков или тест на проникновение). - Списки контроля доступа (ACL) и файерволы приложений могут использоваться для обеспечения дополнительной защиты зоны безопасности, но использование их в качестве единственного средства защиты не является достаточным.			
- Устройства 2-го уровня (устройства уровня канала передачи данных, такие как сетевые коммутаторы – свитчи) могут использоваться совместно между зоной безопасности и другими вариантами использования (разграничение виртуальной локальной компьютерной сети – VLAN). - Административный доступ к сетевым устройствам защищен с использованием либо внеполосной сети, либо через контролируемый внутриполосный доступ (например, административная сеть VLAN). Административный доступ к файерволу (файерволам), защищающему (защищающим) зону безопасности, не зависит от корпоративной системы аутентификации пользователей. - Входящие и исходящие подключения для зоны безопасности максимально ограничиваются. Осуществляется процесс анализа, проверки и применения правил файервола, регулирующих подключение. - Правила файервола «разрешить все» не применяются, и абсолютно все сетевые потоки санкционированы (ведение белого списка). - Как правило, подключение, пересекающее границу зоны безопасности, ограничивается двусторонней связью с бэк-офисными приложениями и MV-SIPN¹, входящей коммуникацией от одобренных ПК оператора общего назначения к промежуточному серверу, а также исходящими административными данными (данные системного журнала операций, резервные копии). - Правила файервола пересматриваются минимум 1 раз в год. - Подключения, пересекающие границу зоны безопасности, файерволы записывают в журнал операций. с.2. Коммуникации между компонентами в зоне безопасности Ограничение коммуникаций между компонентами в зоне безопасности не является обязательным улучшением. При его рассмотрении могут быть реализованы следующие решения: - Сетевые ACL или файерволы узлов, ограничивающие трафик на уровне узла сети в зоне безопасности. - При необходимости можно использовать отдельные аппаратные или сетевые файерволы между компонентами зоны безопасности.			
d. Доступ к системам зоны безопасности d.1. Локальный доступ оператора (конечного пользователя и администратора) - В зоне безопасности реализована одна из следующих схем ограничения доступа оператора (интерактивные сеансы или сеансы командной строки) в зону безопасности: - Операторы подключаются к выделенным ПК, расположенным в пределах зоны безопасности (то есть к ПК, расположенным в зоне безопасности и используемым только для целей этой зоны). - Операторы подключаются со своих ПК общего назначения к зоне безопасности через промежуточный сервер, расположенный в зоне безопасности (например, с помощью решения типа Citrix или сервера терминалов Microsoft). Что касается точки входа в зону безопасности, то промежуточный сервер реализует проверенную практику обеспечения безопасности, в том числе: - обеспечение внедрения всех ЭК из области определения в этом документе (например, обновления для системы безопасности, повышение надежности системы), - отдельный промежуточный сервер для системных администраторов (с многофакторной			

¹ Multi-Vendor Secure IP Network – мультивендорная защищенная IP-сеть

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
аутентификацией) и конечных пользователей, - o ограничение доступа – доступ только к авторизованным операторам, - o удаление любого ненужного программного обеспечения, - o ограничение активности, связанной с рисками (например, отправка / получение электронной почты), - o закрытие доступа в Интернет, - o включение ведения журнала операций. - Операторы подключаются с ПК общего назначения и получают доступ только к интерфейсу обмена сообщениями или коммуникационному интерфейсу через графический интерфейс на базе браузера (например, через Alliance Web Platform). Для этой настройки применяются конкретные ЭК: - o Ограниченный доступ в Интернет на ПК оператора общего назначения с использованием одной из следующих опций: 1. Без доступа к Интернету. 2. Доступ к Интернету с помощью решения типа «удаленный рабочий стол» или «виртуальная машина». 3. Доступ к Интернету с ПК оператора общего назначения только для аккредитованных URL-адресов (из белого списка) через прокси с проверкой контента в сочетании с соответствующими средствами контроля блокировки / фильтрации и разрешением только исходящих инициированных соединений. - o Графический интерфейс на основе браузера расположен в зоне безопасности и логически отделен от интерфейса обмена сообщениями и коммуникации, - o Там, где это необходимо, реализуется многофакторная аутентификация (в графическом интерфейсе на базе браузера, в интерфейсе обмена сообщениями или в коммуникационном интерфейсе), - o Эта настройка не может использоваться для администрирования операционной системы. • Системы SWIFT в зоне безопасности ограничивают административный доступ – доступ только к ожидаемым портам, протоколам и исходным IP-адресам. d. 2. Доступ к удаленному оператору (дистанционный режим работы, «дежурство по вызову» или дистанционное администрирование) • Удаленный доступ к зоне безопасности извне локальной сети пользователей сначала требует аутентификации VPN в локальной сети до доступа к зоне безопасности через те же защищенные каналы, что и локальные операторы. • Оценка риска выполняется пользователем для того, чтобы рассмотреть возможность применения дополнительных средств контроля, которые должны быть реализованы при удаленном доступе, например, использование инфраструктуры виртуальных рабочих столов, выделенных каналов для подключения (например, выделенные промежуточные серверы для удаленных пользователей, арендованные линии). e. Ограничение доступа к Интернету • Доступ в Интернет из систем в зоне безопасности (например, через промежуточный сервер или выделенный ПК оператора) сильно ограничен и по возможности блокируется. - Внедрение архитектуры промежуточного сервера без подключения к Интернету устраняет требование ограничить доступ в Интернет на подключенных отдельных ПК операторов общего назначения. • По возможности деятельность, требующая доступа в Интернет, осуществляется за пределами зоны безопасности. Например, деятельность может включать в себя ежедневную работу на swift.com или загрузку обновлений для системы безопасности для безопасной передачи в зону безопасности. • Если необходим доступ в Интернет из зоны безопасности, доступ должен предоставляться только для целевых URL-адресов, находящихся в белом списке, через прокси-сервер с проверкой контента и соответствующими средствами контроля блокировки / фильтрации. Соединения разрешены только в том случае, если они инициированы в исходящем направлении.			

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
- Не допускается доступ в Интернет общего назначения внутри зоны безопасности. f. Изоляция от общих корпоративных ИТ-сервисов - Для защиты зоны безопасности от кражи учетных данных и (или) компрометации сервисов аутентификации (LDAP, RADIUS, многофакторной) на уровне предприятия в системах зон безопасности используется отдельная система аутентификации от сервиса аутентификации на уровне предприятия. Например, системы зоны безопасности не являются членами службы каталогов предприятия, но вместо этого являются членами службы каталогов зоны безопасности. - Поддерживающая ИТ-инфраструктура, такая как управление ресурсами, базы данных, системы хранения данных, сервисы безопасности (например, установка исправлений – Patch-файлов) и сетевые службы (например, DNS, NTP), используемая в зоне безопасности, защищена от компрометации учетных данных в рамках более крупного предприятия. Учреждения должны провести анализ точек подключения, гарантируя, что эти системы не будут хранить аутентификаторы (пароли, токены и т. д.) для систем и учетных записей в области применения в любом формате (хешированном, зашифрованном, в форме простого текста) вне зоны безопасности. Поддерживающая ИТ-инфраструктура может и не быть эксклюзивной для систем SWIFT и может совместно использоваться в зоне безопасности. Дополнительные улучшения - Системы в зоне безопасности реализуют белый список приложений, позволяя запускать только проверенные приложения.			
Альтернативные методы реализации Учреждения с высоким уровнем зрелости программ безопасности в рамках своих организаций могут рассмотреть возможность внедрения альтернативных элементов контроля, таких как предложены ниже. Конкретные альтернативные решения должны принимать во внимание риски каждой среды и учитывать усилия, необходимые для эффективного внедрения, управления и сопровождения решения. - Сервисы аутентификации в зоне безопасности, не изолированные от сервиса аутентификации на уровне предприятия, потребуют реализации полного набора тщательно проработанных средств контроля для защиты и обнаружения злоумышленников, пересекающих границу зоны безопасности. Средства контроля могут включать в себя ограничения доверительных отношений между более крупной корпоративной средой и зоной безопасности (например, односторонние доверительные отношения), ограничение доступа оператора и администратора, внедрение усиленного контроля за привилегированным доступом, реализация режима «только для чтения» – где это целесообразно, ведение подробного журнала операций и внедрение централизованных функций активного мониторинга и инструментов обнаружения. - Если общие корпоративные ИТ-сервисы (например, сканирование уязвимостей, управление файрволом для защиты границ) распределены между зоной безопасности и другими средами, любые учетные данные, используемые во всей среде, должны контролироваться для того, чтобы гарантировать, что они будут использоваться, только когда и где это необходимо. - Если общий корпоративный сервер первоначально используется для доступа в зону безопасности, то этот сервер используется только для фильтрации легитимного доступа к подключению. Управление идентификацией и доступом пользователей для компонентов зоны безопасности и/или промежуточного сервера по-прежнему возлагается на сервисы аутентификации, предоставляемые в пределах зоны безопасности SWIFT или другой существующей зоны безопасности с аналогичными ЭК. - Если зона безопасности зависит от корпоративных общих функций (таких, как службы каталогов, серверы или сети), которые находятся за пределами области применения, пользователь должен убедиться в том, что любая компрометация таких функций не повлечет за собой компрометацию защиты компонентов, находящихся в области применения.			

1.2. Контроль за привилегированными учетными записями операционной системы

Тип ЭК: обязательный	Применяется к архитектуре:	А 	В
Цель ЭК. Ограничить и контролировать распределение и использование учетных записей операционной системы уровня администратора. Компоненты, входящие в область применения - Зона безопасности: учетные записи операционной системы уровня администратора. Факторы риска - Удаление журналов операций и следов преступлений. - Излишние полномочия или доступ. - Отсутствие отслеживаемости событий. - Несанкционированные изменения системы.			
Руководство по применению Суть ЭК Доступ к учетным записям операционной системы уровня администратора ограничен в максимально возможной степени. Использование контролируется, отслеживается и разрешается только для соответствующих действий, таких, как установка и настройка программного обеспечения, обслуживание, действия в чрезвычайных ситуациях. Во всех других случаях используется учетная запись с наименьшими правами доступа. Контекст ЭК Строгая защита учетных записей уровня администратора операционной системы снижает вероятность использования злоумышленником полномочий учетных записей для совершения атак (например, выполнения команд, удаления следов преступлений). Рекомендации по внедрению - Учетные записи уровня администратора определяются как: - встроенная учетная запись администратора Windows и членов групп с правами администратора (например, учетные записи с правами отладчика или правами на файловую систему). Как правило, это группа администраторов предприятия, группа администраторов домена и группа локальных администраторов; - учетная запись с правами администратора Linux / Unix (ID пользователя = 0) и членов группы с правами администратора; - роль администратора системы мейнфреймов или системного программиста. - Доступ к учетным записям операционной системы уровня администратора максимально ограничен, кроме тех случаев, когда это необходимо для установки, настройки, обслуживания, эксплуатации и поддержки действий, проводимых в чрезвычайных ситуациях. Использование учетной записи уровня администратора ограничено продолжительностью действия (например, в рамках окна обслуживания). - Вход в систему со встроенными учетными записями уровня администратора не разрешен, за исключением тех случаев, когда такие учетные записи необходимы (например, настройка системы) или в экстренных ситуациях (извлечение пароля учетной записи системы контроля доступа в обход обычных процедур в экстренных ситуациях). Вместо этого используются отдельные учетные записи с правами уровня администратора или учетные записи с возможностью получения таких прав (например, «суперпользователь»). - Индивидуальный доступ и использование учетной записи уровня администратора записываются в журнал таким образом, что операции могут быть восстановлены для определения первопричины инцидентов. - Пароли уровня администратора строго контролируются физическими средствами контроля доступа, если они записаны физически.			

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Дополнительные улучшения Системы настроены так, что не позволяют регистрироваться с помощью встроенных учетных записей уровня администратора, кроме как в режиме обслуживания (например, в однопользовательском режиме или в безопасном режиме). Данная мера фактически запрещает вход в учетную запись в качестве сервиса, работы в пакетном режиме, через службы удаленного рабочего стола или путем передачи полномочий с другой учетной записи.			

1.3A. Защита платформы виртуализации

Тип ЭК: рекомендуемый	Применяется к архитектуре:	A 	B
Цель ЭК: Обеспечить защиту платформы виртуализации и виртуальных машин (ВМ) и соответствующих размещенных компонентов, связанных со SWIFT, на том же уровне, как для физических систем. Компоненты, входящие в область применения: - Платформа виртуализации (также называемая гипервизор) и ВМ используются для размещения любых из указанных ниже связанных со SWIFT компонентов: - Интерфейс обмена сообщениями - Коммуникационный интерфейс - Графический интерфейс - SWIFTNet Link - Коннектор - Промежуточный сервер - Выделенные ПК оператора и ПК оператора общего назначения - Файерволы. Факторы риска: - Несанкционированный доступ к гипервизору и его конфигурационным модулям. - Бесконтрольное распространение ВМ, приводящее к трудно поддающимся контролю, неисправным и неучтенным машинам. - Бесконтрольное распространение ВМ, приводящее к несанкционированному доступу к данным. - Отсутствие наглядности внутри сетевой сегрегации и контроля за виртуальными сетями, когда не применяются меры по защите безопасности сетей (такие, как физические файерволы или системы обнаружения вторжений).			
Руководство по применению Суть ЭК Защита платформы виртуализации, виртуальных машин и соответствующей поддерживающей инфраструктуры (например, файерволов) поднимается на тот же уровень, что и для физических систем. Контекст ЭК: С условием того, что соответствующие ЭК внедрены, SWIFT не ограничивает использование виртуальных технологий для любого компонента локальной инфраструктуры SWIFT или соответствующей поддерживающей инфраструктуры (например, виртуальных файерволов). Рекомендации по внедрению: - К платформе виртуализации (иногда также называемой гипервизор), виртуальным машинам и поддерживающей инфраструктуре применяются те же требования по безопасности, что и ко всем другим инфраструктурным системам и компонентам (в том числе, например, ограничения на привилегированный доступ, авторизация при входе в систему, установка исправлений для системы безопасности, ограничение доступа в интернет). - Хост или система платформы виртуализации подлежат физической защите с целью предотвращения несанкционированного физического доступа. - Платформа виртуализации должна быть усилена в соответствии с одним или несколькими пунктами из следующих: - Руководство разработчика по настройке безопасности, - Руководство по настройке безопасности в соответствии с отраслевыми стандартами (например, ² CIS, DISA STIG, NIST), - Стандартная конфигурация безопасности локального или регулятивного органа, или набор ЭК с тем же уровнем требований, что и руководство разработчика или отраслевое руководство. Примечание: SWIFT предполагает, что в будущих версиях этого документа этот ЭК станет обязательным при использовании виртуализации.,.			

² Центр интернет-безопасности; Агентство защиты информационных систем - руководство по реализации технической защиты; Национальный институт стандартов и технологий

2. Уменьшение количества потенциальных векторов атак и уязвимостей

2.1. Безопасность внутреннего потока данных

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Обеспечить конфиденциальность, целостность и аутентификацию потоков данных между локальными приложениями SWIFT и их связь с ПК оператора. Компоненты, входящие в область применения • ПК оператора (или промежуточный сервер). • Компоненты инфраструктуры, связанные со SWIFT. Факторы риска • Нарушение конфиденциальности ключевых данных. • Утеря целостности закрытой информации. • Неаутентифицированный системный трафик. • Неавторизованный доступ.			
Руководство по применению Суть ЭК Механизмы обеспечения конфиденциальности, целостности и аутентификации применяются для защиты связанных со SWIFT потоков данных «приложение – приложение» и «оператор – приложение». Контекст ЭК Защита внутренних потоков данных предотвращает непреднамеренное раскрытие, модификацию и доступ к данным во время их передачи. Рекомендации по внедрению: • Все потоки данных между приложениями, связанными со SWIFT, защищены с помощью механизма безопасности (например, локальная аутентификация (Local Authentication – LAU) в сочетании с защитой конфиденциальности или 2-стороннего TLS) для обеспечения конфиденциальности, целостности и взаимной аутентификации потоков данных. Сюда входят следующие потоки данных: - между приложением RMA и интерфейсом обмена сообщениями, - между графическим интерфейсом пользователя (GUI) и интерфейсом обмена сообщениями, - между графическим интерфейсом пользователя (GUI) и коммуникационным интерфейсом, - между интерфейсом обмена сообщениями и коммуникационным интерфейсом. • Информационное взаимодействие между ПК оператора и приложениями, связанными со SWIFT, защищено с помощью механизма безопасности (например, одностороннего TLS) для обеспечения конфиденциальности, целостности и аутентификации соединения с приложением. • Защищенные протоколы используют текущие общепринятые криптографические алгоритмы (например, AES³, ECDHE⁴), с длиной ключей, соответствующей современным передовым методикам. Более подробные рекомендации по криптографическим алгоритмам, поддерживающим защищенные протоколы, можно найти в Базе знаний SWIFT TIP 5021566.			

³ Расширенный стандарт шифрования (Advanced Encryption Standard – AES)

⁴ Алгоритм Диффи-Хелмана на эллиптических кривых (Elliptic Curve Diffie-Hellman Ephemeral – ECDHE)

2.2. Обновления для системы безопасности

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Минимизировать возникновение известных технических уязвимостей в локальной инфраструктуре SWIFT в соответствии с оцененными рисками путем обеспечения поддержки разработчиками, применения обязательных обновлений программного обеспечения и своевременных обновлений для системы безопасности. Компоненты, входящие в область применения • ПК оператора (или промежуточный сервер): все аппаратное и программное обеспечение. • Зона безопасности: все аппаратное и программное обеспечение. Факторы риска • Использование известных уязвимостей системы безопасности.			
Руководство по применению Суть ЭК Все аппаратное и программное обеспечение внутри зоны безопасности и на ПК операторов находится в рамках жизненного цикла поддержки разработчиком, и при этом все обязательные программные обновления и обновления для системы безопасности своевременно установлены и применены. Контекст ЭК Устранение известных уязвимостей безопасности эффективно сокращает всевозможные методы и подходы, которые может использовать злоумышленник во время атаки. Всеобъемлющий, повторяемый и своевременно реализованный процесс обновления для системы безопасности необходим для непрерывного устранения этих известных уязвимостей, как только становятся доступны исправления по безопасности. Рекомендации по внедрению • Поддержка со стороны разработчиков: - Все программное обеспечение (включая операционные системы) и аппаратное обеспечение (включая сетевые устройства) находится в рамках активного жизненного цикла поддержки продукта разработчиком (включая расширенную поддержку), если это применимо. - Имеются контракты на обслуживание или лицензионные договоры для доступа к обновлениям, незначительным улучшениям и другим важным функциям обслуживания. • Обязательные обновления программного обеспечения: - Обязательные релизы или обновления, применимые к локальному компоненту SWIFT, устанавливаются в срок, указанный разработчиком. • Применение обновлений для системы безопасности: - Процесс оценки рисков предназначен для определения наиболее оптимального обновления/исправления для системы безопасности из имеющихся у разработчика. Факторы, которые необходимо учитывать при оценке рисков, могут включать в себя установленную разработчиком важность исправлений, подверженность внешнему воздействию и уязвимость пользователей, механизмы смягчения и операционное воздействие. - Определяемые пользователем временные рамки установки исправлений формируются на основе критичности, типа системы и необходимости тестирования исправлений. - При отсутствии установленных внутренних процессов и временных рамок SWIFT рекомендует использовать общую систему для оценки уязвимостей (CVSS) версии 3 в качестве руководства по критическим режимам, со следующими уровнями и сроками применения исправлений: - o Критический уровень (оценка 9.0+): исправление применяется в течение одного месяца после релиза. - o Высокий уровень (оценка 7.0 – 8.9): исправление применяется в течение двух месяцев с момента релиза. - o Низкий / средний (оценка <7.0): определяется пользователем.			

- Проверка источника и целостности обновлений программного обеспечения и системы безопасности:
 - Перед применением обновлений программного обеспечения и системы безопасности проверяется, является ли источник этих обновлений легитимным, кроме того необходимо выполнить проверки целостности (например, проверка контрольных сумм).

2.3. Повышение надежности системы

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Уменьшить количество потенциальных векторов кибератак на компоненты, связанные с SWIFT, путем повышения надежности системы. Компоненты, входящие в область применения - Операционные системы для ПК оператора (или промежуточного сервера). - Операционные системы для приложений, связанных со SWIFT. - Поддержка инфраструктуры в зоне безопасности (например, фаерволы, маршрутизаторы). Примечание: SWIFT HSM – это устройства уровня 3 согласно FIPS 140-2 (Федеральный стандарт по обработке информации), отвечающие требованиям защищенной базовой ОС, и которые находятся вне области применения данного ЭК. Факторы риска - Избыточное количество потенциальных векторов атак. - Использование небезопасной конфигурации системы.			
Руководство по применению Суть ЭК Усиление безопасности осуществляется и поддерживается по всем компонентам в области применения. Контекст ЭК Повышение надежности системы подразумевает применение концепции безопасности «минимальные полномочия» для системы путем отключения функций и сервисов, которые не требуются для обычных операций системы. Этот процесс уменьшает возможности системы, функции и протоколы, которые злоумышленник может использовать во время атаки. Рекомендации по внедрению - Надежность всех систем, входящих в область применения, повышается в соответствии с одним или несколькими документами из следующих: - Руководство разработчика по настройке безопасности. - Руководство по настройке безопасности в соответствии с отраслевыми стандартами (например, ⁵ CIS, DISA STIG, NIST). - Стандартная конфигурация безопасности или стандартный набор ЭК локального или регулятивного органа с тем же уровнем требований, что и руководство разработчика или отраслевое руководство. - Конфигурации целевого повышения надежности могут быть изменены в соответствии с требованиями к конфигурации конкретного приложения для поддержания надлежащего рабочего состояния систем, связанных со SWIFT. - Процесс повышения надежности как минимум должен: - изменить пароли по умолчанию, - отключить или удалить ненужные учетные записи пользователей, - отключить или ограничить ненужные службы, порты и протоколы, - удалить ненужное программное обеспечение, - ограничить работу физических портов (например, USB) согласно установленному порядку, - провести перенастройку всех уязвимых конфигураций, имеющих настройку «по умолчанию». Перечисленные выше стандарты разработчиков и отраслевые стандарты могут предоставить подробные рекомендации по выполнению этих минимальных целей.			

⁵ CIS – Центр интернет-безопасности; DISA STIG – Агентство защиты информационных систем – руководство по реализации технической защиты; NIST – Национальный институт стандартов и технологий

- Отклонения от выбранного стандарта повышения надежности документируются наряду с обоснованием отклонения и возможными мерами для смягчения последствий отклонения.
- Защита систем поддерживается путем:
 - регулярной, не реже двух раз в год, проверкой систем по параметрам безопасности, определенным согласно рекомендациям выше, для того, чтобы принять все соответствующие корректирующие действия,
 - или регулярным применением определенных согласно рекомендациям параметров безопасности.

2.4А. Безопасность передачи данных из бэк-офиса

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
Цель ЭК. Обеспечить конфиденциальность, целостность и взаимную аутентификацию передачи данных между приложениями бэк-офиса (или промежуточного ПО) и подключаемыми компонентами инфраструктуры SWIFT. Компоненты, входящие в область применения - Слой обмена данными: передача финансовых транзакций . Факторы риска - Нарушение конфиденциальности ключевых данных. - Нарушение целостности конфиденциальной информации. - Неаутентифицированный системный трафик.			
Руководство по применению Суть ЭК Механизмы конфиденциальности, целостности и взаимной или на основе иерархии уровней сообщений аутентификации реализованы для защиты передачи данных между приложениями бэк-офиса (или промежуточного ПО) и подключаемыми компонентами инфраструктуры SWIFT. Контекст ЭК Защита передачи данных между бэк-офисом (или промежуточным ПО), первый сегмент сети, как видно из зоны безопасности, и подключаемой инфраструктурой SWIFT предохраняет от атак типа «незаконный посредник», а также от непреднамеренного разглашения, модификации и доступа к данным во время передачи. Рекомендации по внедрению - Безопасность передачи данных между системами бэк-офиса (или системами промежуточного ПО) и напрямую подключенными компонентами инфраструктуры SWIFT обеспечивается с помощью защищенного механизма (например, «LAU в сочетании с защитой конфиденциальности» или иные основанные на обмене сообщениями аутентификационные решения, XML DSIG, аутентифицированное шифрование AES GCM, 2-сторонний TLS), который обеспечивает конфиденциальность, целостность и взаимную аутентификацию потоков данных. - Защищаются потоки данных между: - бэк-офисом (или промежуточным ПО) и интерфейсом обмена сообщениями, - бэк-офисом (или промежуточным ПО) и коммуникационным интерфейсом, - бэк-офисом (или промежуточным ПО) и коннектором. - Защищенные протоколы используют текущие общепринятые криптографические алгоритмы (например, AES⁶, ECDHE⁷) с длиной ключей в соответствии с современными передовыми методами. Более подробные рекомендации по криптографическим алгоритмам, поддерживающим защищенные протоколы, можно найти в Базе знаний SWIFT TIP 5021566. Примечания - Для приложений промежуточного ПО (таких как IBM® MQ), напрямую подключающихся к компонентам инфраструктуры SWIFT, предполагается, что пользователи обеспечат одинаковый уровень защиты между этим уровнем промежуточного ПО и приложениями бэк-офиса. Таким образом, сквозная цепочка транзакций (между системами бэк-офиса и инфраструктурой SWIFT) будет защищена. - Несмотря на то что этот ЭК классифицируется как рекомендуемый, SWIFT настоятельно предлагает внедрять механизмы защиты конфиденциальности, целостности и аутентификации, как прописано в рекомендациях по внедрению. - SWIFT ожидает, что этот ЭК станет обязательным в будущей версии этого документа.			

⁶ Расширенный стандарт шифрования (Advanced Encryption Standard – AES)

⁷ Алгоритм Диффи-Хелмана на эллиптических кривых (Elliptic Curve Diffie-Hellman Ephemeral – ECDHE)

2.5A. Защита данных при передаче во внешнюю среду

Тип ЭК: рекомендуемый	Применяется к архитектуре:	A	B
Цель ЭК. Защищать конфиденциальность передаваемых данных, связанных со SWIFT и находящихся за пределами зоны безопасности. Компоненты, входящие в область применения - Данные зоны безопасности, связанные со SWIFT. Факторы риска - Компрометация достоверных резервных данных. - Нарушение конфиденциальности ключевых данных.			
Руководство по применению Суть ЭК Связанная со SWIFT конфиденциальная информация, покидающая зону безопасности в результате создания резервных копий, репликации данных для обеспечения возможности восстановления или последующей офлайн обработки, зашифровывается. Контекст ЭК Шифрование конфиденциальных данных, покидающих зону безопасности, защищает от непреднамеренного раскрытия информации, когда она извлекается из своей обычной операционной среды. Рекомендации по внедрению - Связанная со SWIFT конфиденциальная информация в соответствии с классификацией внутренних данных пользователей или применимыми законами и нормативно-правовыми актами (как минимум это полезные данные сообщений, архивы, пароли и другие аутентификаторы) зашифровываются, когда: - данные забираются из зоны безопасности (например, резервные копии, архивы), - данные передаются между зонами безопасности (например, между центрами обработки и хранения данных). - Протоколы шифрования используют текущий общепринятый криптографический алгоритм (например, AES⁸, ECDHE⁹) с длиной ключа в соответствии с современными передовыми методами. Более подробные рекомендации по криптографическим алгоритмам, поддерживающим на данный момент защищенные протоколы, можно найти в Базе знаний SWIFT TIP 5021566. - Передача зашифрованных данных соответствует действующим законам и нормативно-правовым актам. - Если скомпрометирована криптография, защищающая данные SWIFT, должен быть установлен процесс для применения новой криптографии и защиты или уничтожения любых скомпрометированных копий данных. Альтернативные методы реализации - Если данные не могут быть зашифрованы, передача данных за пределы зоны безопасности как минимум должна быть защищена путем использования зашифрованной сети или транспортного уровня, а данные защищены в пункте назначения.			

⁸ Расширенный стандарт шифрования (Advanced Encryption Standard – AES)

⁹ Алгоритм Диффи-Хелмана на эллиптических кривых (Elliptic Curve Diffie-Hellman Ephemeral – ECDHE)

2.6. Конфиденциальность и целостность сессии оператора

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Защищать конфиденциальность и целостность интерактивных сессий оператора, подключающихся к локальной инфраструктуре SWIFT. Компоненты, входящие в область применения. • ПК оператора (или промежуточный сервер): сессии операционной системы. • ПК оператора (или промежуточный сервер): сессии интерфейсных приложений в зоне безопасности. • Зона безопасности: сессии HSM и связанных со SWIFT приложений и операционных систем с выделенных ПК оператора. Факторы риска • Нарушение операционной конфиденциальности. • Нарушение операционной целостности.			
Руководство по применению Суть ЭК Обеспечивается конфиденциальность и целостность интерактивных сессий операторов, подключающихся к зоне безопасности. Контекст ЭК Сессии операторов с локальной инфраструктурой SWIFT представляют собой особую угрозу, так как необычную или неожиданную активность труднее обнаружить во время интерактивных сессий, чем во время работы приложения с приложением. Поэтому важно защитить целостность и конфиденциальность этих сессий для уменьшения любой возможности нештатного использования. Рекомендации по внедрению • Все интерактивные сессии защищены криптографическим протоколом (например, ssh, https). • Протоколы шифрования используют текущий общепринятый криптографический алгоритм (например, AES¹⁰, ECDHE¹¹) с длиной ключа в соответствии с современными передовыми методами. Более подробные рекомендации по криптографическим алгоритмам, поддерживаемым на данный момент защищенные протоколы, можно найти в Базе знаний SWIFT TIP 5021566. • Сессии операторов и другие типы сессий (например, мониторинг или обслуживание) имеют функцию блокировки в случае бездействия, которая ограничивает сессию до минимального временного интервала, необходимого для выполнения стандартных обязанностей. - Для сессий конечного пользователя рекомендуется блокировка через 15 минут бездействия. • Если тайм-аут не реализован на уровне приложения, он должен быть реализован на уровне операционной системы приложения или на промежуточном сервере.			

¹⁰ Расширенный стандарт шифрования (Advanced Encryption Standard – AES)

¹¹ Алгоритм Диффи-Хелмана на эллиптических кривых (Elliptic Curve Diffie-Hellman Ephemeral – ECDHE)

2.7. Сканирование на уязвимость системы

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Определить известные уязвимости в локальной среде SWIFT путем внедрения регулярного процесса сканирования уязвимостей и принятия мер по результатам сканирования. Компоненты, входящие в область применения • ПК оператора (или промежуточный сервер). • Зона безопасности: все связанные со SWIFT приложения и операционные системы. Факторы риска • Использование известных уязвимостей системы безопасности.			
Руководство по применению Суть ЭК Системы зоны безопасности и ПК оператора сканируются на наличие уязвимостей с использованием современного, заслуживающего доверия инструмента сканирования, и результаты сканирования используются для выработки соответствующих корректирующих действий. Контекст ЭК Обнаружение известных уязвимостей позволяет их анализировать, обрабатывать и смягчать. Смягчение уязвимостей сокращает число методов и способов, которые злоумышленник может использовать во время атаки. Процесс сканирования уязвимостей, который является всеобъемлющим, повторяемым и выполняется своевременно, необходим для непрерывного обнаружения известных уязвимостей и принятия дальнейших мер. Рекомендации по внедрению • Сканирование уязвимостей выполняется не реже одного раза в год, а также после любого существенного изменения среды (например, замена серверных компонентов на новые, изменения сетевой структуры). - Средства сканирования уязвимостей – от заслуживающего доверия разработчика, профили сканирования в этих средствах обновляются в течение одного месяца до сканирования. - Для среды выбран наиболее подходящий тип сканирования уязвимостей (с использованием учетных данных или черного ящика). Любые административные учетные данные, используемые для сканирования, защищены надлежащим образом. - Надлежащие меры безопасности, основанные на оценке рисков, нацелены на уменьшение любого негативного воздействия (например, запуск сканирования в безопасном режиме или исключение систем, которые могут пострадать от сканирования). • Все тесты на оценку уязвимостей в отношении сервисов и продуктов, связанных со SWIFT, согласуются с Политикой тестирования пользователей. • Результаты сканирования уязвимостей документируются (с ограниченным доступом) и анализируются для выполнения соответствующего действия и устранения (например, применение обновлений для системы безопасности в соответствии с ЭК 2.2). • Рекомендуется выполнять сканирование ежеквартально, ежемесячно или, в идеале, в режиме реального времени.			

2.8A. Аутсорсинг критически важных видов деятельности

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
Цель ЭК. Обеспечить защиту локальной инфраструктуры SWIFT от рисков, связанных с передачей на аутсорсинг критически важных видов деятельности. Компоненты, входящие в область применения - Организационный контроль. Факторы риска - Подверженность нестандартным методам обеспечения безопасности.			
Руководство по применению Суть ЭК Критически важные виды деятельности организации, переданные на аутсорсинг, защищены как минимум таким стандартом обслуживания, как если бы они осуществлялись внутри организации. Контекст ЭК Когда критически важные виды деятельности, такие как обслуживание сети и системы, передаются третьей стороне (например, внешнему поставщику ИТ-услуг), важно, чтобы как минимум поддерживался первоначальный стандарт обслуживания (в дополнение к соблюдению этой Концепции обеспечения безопасности пользователей), чтобы не допустить возникновения новых слабых мест или уязвимостей. Примечание - SWIFT определяет следующие операции как критические: - управление безопасностью и управление изменениями аппаратного и программного обеспечения (включая приложения и операционную систему), поддерживающего сервисы SWIFT, - операции, связанные с RMA, - доступ к конфиденциальным данным пользователя (например, к содержимому сообщения), - мониторинг событий, содержащих конфиденциальные данные пользователя, - управление и настройка сети, - транзакционные операции, связанные со SWIFT (например, создание или изменение финансового транзакционного сообщения в интерфейсе обмена сообщениями). Рекомендации по внедрению - Договор о сервисном обслуживании (Service Level Agreements – SLA) и соглашение о неразглашении конфиденциальной информации (Non-Disclosure Agreement – NDA) подписываются с любой третьей стороной, которой были переданы критически важные виды деятельности. Эти SLA определяют стандарт обслуживания, в рамках которого осуществляются эти критические операции третьей стороной. - Оценка рисков третьей стороны проводится в начале взаимодействия и далее проводится на регулярной основе.			

2.9А. Средства контроля транзакционного бизнеса

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
Цель ЭК. Ограничить транзакционную активность до проверенных и одобренных контрагентов и в рамках ожидаемых границ обычной деятельности. Этот ЭК необходим для • графического интерфейса. • зоны безопасности: интерфейс обмена сообщениями. • зоны безопасности: коммуникационный интерфейс. • зоны безопасности: коннектор. Факторы риска • Ведение бизнеса с несанкционированным контрагентом. • Нераспознанные аномалии или подозрительная активность.			
Руководство по применению Суть ЭК Внедрить средства контроля RMA и средства обнаружения, предупреждения и проверки транзакций с целью ограничения транзакционной активности до ожидаемых границ или обычной деятельности. Контекст ЭК Внедрение средств бизнес-контроля, ограничивающих транзакции SWIFT в максимально возможной степени, уменьшает возможность как для отправки, так и для получения мошеннических транзакций. Эти ограничения лучше всего определяются посредством анализа обычной деловой активности. Параметры затем могут быть установлены для ограничения бизнеса до приемлемых пороговых значений на основе «обычной» деятельности. Рекомендации по внедрению • Сервис по управлению взаимоотношениями (RMA): - Соответствующие принципы «знай своего клиента» и «due diligence» выполняются во время создания и поддержки сервиса RMA. - Взаимоотношения в рамках RMA проверяются не реже одного раза в год для обеспечения своевременного удаления неактуальных взаимоотношений. • Контроль транзакций: - Внедрить средства контроля, которые будут обнаруживать, предотвращать или дополнительно проверять транзакции за пределами ожидаемых границ или обычной деятельности. Примеры включают следующее: - o Передача и подтверждение транзакций SWIFT вне обычных рабочих часов ограничены. В случае круглосуточной централизованной обработки SWIFT – ограничение или мониторинг транзакций для поддержки бизнеса в обычном режиме. - o Имеется процесс выдачи и проверки подтверждения сообщений (например, для проверки подтверждений MT900 и MT910 на соответствие транзакциям, которые были проведены по счетам). - o Сверка данных бухгалтерского учета организации с выписками по счетам в конце дня (например, MT 940 Выписка по счету клиента и MT 950 Выписка). - o Сверка выполняется ежедневно между сообщениями, которые отправляются в бэк-офис / из бэк-офиса и в сеть / из сети SWIFT. - o Номера сеансов в интерфейсе обмена сообщениями отслеживаются для того, чтобы гарантировать, что последовательная нумерация сеансов сохраняется, то есть не содержит неожиданных разрывов. - o Ограничение активных сеансов SWIFTNet FIN рабочими часами (например, автоматический выход из сеансов логических терминалов в конце рабочего дня). В случае круглосуточной централизованной обработки SWIFT – ограничение или мониторинг транзакций для поддержки			

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
бизнеса в обычном режиме. - о Отслеживание нехарактерных транзакций (например, крайне высокие суммы, необычные бенефициары или валюты). Дополнительные улучшения • Учетные записи приложений и операционной системы ограничены в попытках входа в систему, которые происходят вне ожидаемых рабочих часов, зависящих от конкретной роли. • Независимая сверка выполняется с данными о транзакциях пользователей, полученных защищенным образом из вторичного источника (например, с использованием ежедневных отчетов по валидации от SWIFT) или путем подтверждения у отправителя или получателя того, что транзакция является подлинной.			

2.10А. Повышение надежности приложений

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
Цель ЭК: Уменьшить количество потенциальных векторов кибератак на компоненты, связанные с SWIFT, путем повышения надежности приложений на сертифицированных SWIFT интерфейсах обмена сообщениями и коммуникационных интерфейсах. Компоненты, входящие в область применения: • Интерфейс обмена сообщениями. • Коммуникационный интерфейс. • Графический интерфейс. • SWIFTNet Link. • Коннектор. • Дополнительные приложения, установленные на указанных выше компонентах, для обработки данных, связанных со SWIFT. Факторы риска: • Избыточное количество потенциальных векторов атак. • Использование небезопасной конфигурации приложения.			
Руководство по применению Суть ЭК Все интерфейсы обмена сообщениями (например, Alliance Access, Alliance Messaging Hub и им подобные) и коммуникационные интерфейсы (например, Alliance Gateway и ему подобные), функционирующие внутри зоны безопасности, сертифицированы SWIFT. Повышение уровня безопасности осуществляется и поддерживается по всем компонентам в области применения. Контекст ЭК Повышение надежности приложения подразумевает применение концепции безопасности «минимальные полномочия» для приложения, путем отключения функций и сервисов, которые не требуются для обычного использования. Этот процесс уменьшает возможности, особенности и протоколы приложения, которые злоумышленник может использовать во время совершения атаки. Это также гарантирует, что предполагаемый стандартный набор полномочий будет изменен. В дополнение к этому SWIFT запускает Программу сертификации интерфейсов для того, чтобы привести интерфейсы в соответствие с текущей практикой и дать пользователю дополнительные уверенность, гарантии, и лучшее понимание относительно отдельных возможностей продуктов. После успешной проверки результатов тестов соответствующим компетентным органом SWIFT (SWIFT Test Authority), данные сертификации публикуются в справочнике по сертификации (Certification Register). Согласно Общим положениям и условиям SWIFT пользователи должны использовать сертифицированные интерфейсы. Рекомендации по внедрению • Убедиться в том, что интерфейсы обмена сообщениями и коммуникационные интерфейсы сертифицированы SWIFT (список сертифицированных интерфейсов публикуется в справочнике по сертификации на www.swift.com). – Интерфейс, сертифицированный SWIFT, должен отвечать всем требованиям безопасности (и обязательным, и рекомендуемым), определенным в Программе SWIFT по сертификации интерфейсов (SWIFT Certified Interface Programme). Если некоторые требования безопасности еще не выполнены, пользователь должен перейти на сертифицированный интерфейс, реализуя соответствие, по крайней мере, обязательным требованиям безопасности. В случае возникновения сомнений относительно наличия некоторых функций безопасности или их правильной настройки и использования, следует обратиться к поставщику интерфейса. • Надежность всех приложений, входящих в область применения, повышается в соответствии с одним или несколькими документами из следующих: – Руководство разработчика по безопасности, эксплуатации и конфигурированию – Стандартная конфигурация безопасности локального или регулятивного органа или набор ЭК с тем же уровнем требований, что и в руководстве разработчика.			

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
• Как минимум, в рамках процесса повышения надежности приложений необходимо: – Изменить существующие по умолчанию пароли, – Отключить или удалить ненужные учетные записи пользователей, – Отключить или ограничить ненужные компоненты, адаптеры или коннекторы, – Настроить как следует адаптеры, коннекторы или удаленные подключения, – Удалить ненужные пакеты (программ) – Настроить все уязвимые стандартные конфигурации. • Отклонения от выбранных правил повышения надежности документируются наряду с обоснованием таких отклонений. Примечание: SWIFT предполагает, что этот ЭК станет обязательным в будущих версиях этого документа.			

3. Обеспечение физической безопасности среды

3.1. Физическая защита

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Предотвратить несанкционированный физический доступ к ключевому оборудованию, рабочим местам, местам размещения оборудования и хранилищам. Компоненты, входящие в область применения • ПК оператора (или промежуточный сервер), включая съемное оборудование. • Зона безопасности: все аппаратное обеспечение. • Платформа виртуализации (также называемая гипервизор). Примечание. Alliance Connect VPN box в целом находятся вне области применения, но ожидается, что они будут входить в среду с соответствующими физическими ЭК, как описано ниже. Факторы риска • Отсутствие отслеживаемости событий. • Несанкционированный физический доступ.			
Руководство по применению Суть ЭК Средства физической защиты необходимы для защиты от несанкционированного доступа к ключевому оборудованию, местам размещения оборудования и хранилищам. Контекст ЭК Внедрение средств физической защиты позволяет обезопасить себя от внутренних и внешних угроз и снижает возможность масштабных (ненаправленных) атак, реализуемых через физический доступ к системам. Рекомендации по внедрению • Обеспечение защиты съемного оборудования: - Ключевое съемное оборудование (например, устройство ввода PIN-кода (PED), ключи PED, смарт-карты, связанные со SWIFT, USB-токены, устройства TOTP) находится под наблюдением или надежно защищено, когда оно хранится и не используется. - Ключевое съемное оборудование, необходимое для обычной непрерывной работы (например, диски, заменяемые в горячем режиме, устройства HSM) размещается в центре обработки данных или, по крайней мере, в запечатанном помещении. - Резервные носители (например, ленты) физически защищены. • Обеспечение защиты рабочей среды: - ПК операторов находятся в защищенной рабочей среде, где доступ контролируется и предоставляется только штатным сотрудникам и другим авторизованным работникам и посетителям. Отдельная физическая зона для ПК операторов, имеющих доступ к системам SWIFT, не требуется. - Принтеры, используемые для транзакций SWIFT, находятся в защищенной рабочей среде, и доступ к ним ограничен. - USB и другие внешние точки доступа на ПК оператора в максимально возможной степени отключены, сохраняя при этом поддержку вспомогательных операций (например, когда необходимо подключать токены для аутентификации операций сообщений). • Обеспечение защиты сотрудников, работающих в «дистанционном режиме» (например, на дому или работающий на дежурстве «по вызову» операционный персонал). - Политика безопасности устанавливается для поддержки ожидаемых сценариев использования для сотрудников, работающих в «дистанционном режиме». При создании политики учитываются следующие пункты: - o физическая защита предполагаемой дистанционной среды,			

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
	- о правила для персонального оборудования, используемого для деловых целей SWIFT (например, персональные компьютеры не могут использоваться для доступа к инфраструктуре SWIFT, однако персональные мобильные устройства могут использоваться в целях двухфакторной аутентификации), - о обеспечение защиты во время работы в общественных местах, - о безопасность в общественном и частном транспорте, - о хранение оборудования, - о неавторизованный доступ к оборудованию (например, родственников или друзей), - о требования к удаленному доступу (рекомендуется VPN с многофакторной аутентификацией), - о защита мобильных устройств, используемых для аутентификации, например, проверки OTP или SMS-верификации (рекомендуется включить пароль и автоматическую блокировку), - о компенсирующие ЭК (например, виртуальный рабочий стол, препятствующий локальному хранению данных, полное шифрование диска), - о отчеты об инцидентах безопасности (например, кража) при работе в «дистанционном режиме».. • Обеспечение защиты серверной среды: - Серверы размещаются в центре обработки данных или как минимум в закрытом помещении с ограниченным и контролируемым доступом (например, с использованием карт контроля доступа или биометрических данных). - о В идеале серверы закрепляются в стойке. Проводится оценка риска, чтобы определить, соответствует ли отдельная и эксклюзивная стойка или крепление стойки физическим средствам контроля доступа в центр обработки данных. - В серверной среде имеется система видеонаблюдения с оборудованием обнаружения движений и записи видео. Реализация записи и хранения видео соответствует действующим законам и нормативно-правовым актам. По возможности записи хранятся в течение как минимум трех месяцев. - На серверах отсутствует физическая ссылка на SWIFT (например, ярлыки). - Внешние порты (например, USB, последовательная шина) на серверах в максимально возможной степени отключены, однако при этом сохраняется поддержка вспомогательных операций. • Регистрация и контроль физического доступа: - Регистрируется физический доступ в зоны с ключевым оборудованием (например, в центр обработки и хранения данных, в защищенное хранилище). - Журналы физического доступа доступны для аудита и расследований и хранятся в течение как минимум 12 месяцев и соответствуют действующим законам и нормативно-правовым актам. - Физический доступ незамедлительно аннулируется (или изменяется), когда сотрудник меняет роли или покидает организацию. - Списки контроля физического доступа пересматриваются не реже одного раза в год.	●	●

4. Предотвращение компрометации учетных данных

4.1. Политика паролей

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Обеспечить достаточную устойчивость паролей к распространенным парольным атакам путем внедрения и применения эффективной политики паролей. Компоненты, входящие в область применения - Вход в систему на ПК оператора (или на промежуточном сервере). - Зона безопасности: учетные записи приложений и операционной системы. - Персональные токены и персональные мобильные устройства, используемые как отделяемый носитель информации (фактор владения) для многофакторной аутентификации (см. ЭК 4.2). Факторы риска - Взлом, подбор или другая компьютерная компрометация паролей.			
Руководство по применению Суть ЭК Все учетные записи приложений и операционной системы защищены паролями с соответствующими параметрами, такими как длина, сложность, корректность и количество неудачных попыток входа в систему. Аналогичным образом персональные токены и мобильные устройства защищены паролями или персональным идентификационным кодом (ПИН-кодом) с соответствующими параметрами. Контекст ЭК Реализация политики паролей, защищающая от распространенных парольных атак (например, угадывание, полный перебор), эффективна для защиты от компрометации учетной записи. Злоумышленники часто используют полномочия скомпрометированной учетной записи, чтобы внедриться в среду и осуществить атаку. Другой риск – это компрометация локальных ключей аутентификации для нарушения целостности транзакций. Тем не менее важно осознавать, что одних паролей, как правило, недостаточно в текущей ситуации с киберугрозами. Пользователи должны учитывать этот ЭК в тесной связи с требованием многофакторной аутентификации Рекомендации по внедрению - Политика паролей, включающая также правила настройки ПИН-кодов, соответствующая действующим отраслевым стандартам или лучшим видам отраслевой практики, установлена и определяет следующие параметры: - срок действия пароля, - длина пароля, состав, сложность и другие ограничения, - повторное использование паролей, - блокировка после неудачных попыток аутентификации и способ ее снятия, - требования к паролям могут быть изменены, если это необходимо для конкретных сценариев использования: - при двухфакторной аутентификации (например, одноразовый пароль), - цель аутентификации (например, операционная система, приложение, мобильное устройство, токен), - тип учетной записи (обычный оператор, привилегированный оператор, учетная запись для взаимодействия типа «приложение – приложение» или локальные ключи аутентификации). Более подробные рекомендации по настройке параметров паролей и ПИН-кодов можно найти в Базе знаний SWIFT TIP 5021567 и 5022038. - Политика паролей разработана с учетом известных парольных уязвимостей в вычислительной среде. Например, требование пароля, состоящего более чем из 15 символов, для систем Windows,			

предохраняет Windows от вычисления весьма уязвимого хеш-пароля LM (LAN Manager).			
Тип ЭК: обязательный	Применяется к архитектуре:	A	B
- Установленная политика паролей обеспечивается с помощью технических средств (например, с помощью групповой политики Active Directory или в рамках параметров приложений), где это возможно. - Эффективность политики паролей пересматривается регулярно (рекомендуется один раз в год). - Системные настройки, связанные с управлением паролями и их хранением, приведены в соответствие с отраслевыми стандартами и передовыми методами разработчиков (например, включение параметра реестра NoLMHash в Windows). - Пароли, используемые для систем зоны безопасности, гораздо более уязвимы, если они хранятся в системах аутентификации вне зоны безопасности (например, в корпоративной службе каталогов Active Directory). Вместо этого пароли для систем зоны безопасности следует в максимально возможной степени хранить только в пределах зоны (например, в службе каталогов Active Directory для производственных систем), как описано в руководстве по проектированию зоны безопасности. Примечание Важно, чтобы пользователи использовали надежные пароли и, предпочтительно, строгую аутентификацию для всех систем, используемых в цепочке сквозных транзакций, и не ограничивали эти средства контроля только инфраструктурой SWIFT.			

4.2. Многофакторная аутентификация

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Предотвратить ситуацию, когда компрометация одного фактора аутентификации позволяет получить доступ к системам SWIFT, путем реализации многофакторной аутентификации. Компоненты, входящие в область применения В зависимости от реализации: - Вход в систему на ПК оператора. - Доступ оператора к промежуточному серверу. - Процесс входа оператора в интерфейс обмена сообщениями (включая размещенную базу данных) и коммуникационный интерфейс. - Операционная система, поддерживающая интерфейс обмена сообщениями (включая размещенную базу данных) и коммуникационный интерфейс. Факторы риска - Воспроизведение учетных данных. - Взлом, подбор или другая компьютерная компрометация паролей. - Кража паролей.			
Руководство по применению Суть ЭК Многофакторная аутентификация используется для интерактивного доступа пользователей к связанным со SWIFT приложениям и учетным записям операционной системы. Контекст ЭК Многофакторная аутентификация требует представления двух или более упомянутых ниже распространенных факторов аутентификации: - Фактор знаний (то, что знает оператор), как правило, пароль. - Фактор владения (то, чем владеет оператор), как правило: - подключаемые токены (например, USB-токены, смарт-карты), - неподключаемые токены (например, генераторы одноразовых паролей с использованием мобильного телефона операторов, токена RSA или Digipass). - Фактор неотделимости (что-то, что является оператором), как правило, биометрические данные, такие как отпечатки пальцев, сканирование сетчатки или распознавание голоса. Внедрение многофакторной аутентификации обеспечивает дополнительный уровень защиты от распространенных аутентификационных атак (например, «взгляд через плечо», повторное использование пароля или использование ненадежных паролей) и обеспечивает дополнительную защиту от компрометации учетной записи. Злоумышленники часто используют полномочия скомпрометированной учетной записи, чтобы внедриться в среду и осуществить атаку. Рекомендации по внедрению - Когда реализуется многофакторная аутентификация, применяются следующие принципы: - Когда берется за основу фактор знаний (обычно – пароль) в сочетании с фактором владения (мобильное устройство), устройство, используемое для второго фактора не должно быть тем же устройством, которое используется для первого фактора. Соответственно, использование приложения для формирования второго фактора на том же устройстве / ПК, которое используется для ввода первого фактора (пароля), не признается достаточным для доступа к локальным системам SWIFT. - Решения по второму фактору, основанному на факторе владения (не исчерпывающий перечень): TOTP, RSA SecurID, Digipass, Mobile App, Transaction Authentication Number (TAN) Table, personal USB token. Выбор решения осуществляется с учетом принятой у			

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
пользователя системы управления рисками. - Фактор неотделимости является более безопасным в сочетании с фактором владения, чем с фактором знаний. • Многофакторная аутентификация реализуется по меньшей мере на одном этапе/шаге аутентификации, которые проходит конечный пользователь при осуществлении доступа к приложению SWIFT: для администраторов операционной системы: - o на границе зоны безопасности (промежуточный сервер), - o на выделенном ПК оператора при входе в систему (внутри зоны безопасности); - для конечных пользователей в порядке убывания отказоустойчивости в области безопасности: - o в отдельных приложениях SWIFT (в графическом интерфейсе на базе браузера, в интерфейсе обмена сообщениями или в коммуникационном интерфейсе), - o на границе зоны безопасности (промежуточный сервер), - o на выделенном ПК оператора при входе в систему (т.е. внутри зоны безопасности). • Многофакторная аутентификация применяется для удаленного административного доступа, как правило, для аутентификации VPN. • Многофакторные системы аутентификации значительно более уязвимы, если учетные данные аутентификации хранятся вне зоны безопасности (например, в корпоративной службе каталогов Active Directory). Если это возможно, система аутентификации, поддерживающая многофакторное решение, должна находиться в зоне безопасности. • Представленные факторы аутентификации назначаются индивидуально и поддерживают индивидуальный учет доступа к службам, операционной системе и приложениям. • Если реализован разовый вход (например, SAML), то по-прежнему требуется второй фактор для однократного входа или на более позднем этапе. Примечание Все интерфейсы обмена сообщениями и коммуникационные интерфейсы SWIFT и сертифицированных SWIFT сторонних разработчиков должны поддерживать или иметь встроенную многофакторную аутентификацию.			

5. Управление идентификационными данными и разграничение полномочий

5.1. Логический контроль доступа

Тип ЭК: обязательный	Применяется к архитектуре:	A	B
Цель ЭК. Обеспечить соблюдение принципов безопасности: доступ к информации только по служебной необходимости, минимальные полномочия и разграничение обязанностей для учетных записей операторов. Компоненты, входящие в область применения - Все учетные записи операторов (например, операционных систем, приложений и модулей HSM). Факторы риска - Излишние полномочия или доступ. - Нарушения в разграничении обязанностей. - Несанкционированный доступ.			
Руководство по применению Суть ЭК Учетные записи определяются в соответствии с принципами безопасности: доступ к информации только по служебной необходимости, минимальные полномочия и разграничение обязанностей. Контекст ЭК Применение принципов безопасности: (1) служебная необходимость, (2) минимум полномочий и (3) разграничение обязанностей – является важным для ограничения доступа к локальной инфраструктуре SWIFT. Эффективное управление учетными записями операторов сокращает возможность использования учетных записей злоумышленником в рамках осуществления атаки. Рекомендации по внедрению Политика логического контроля доступа задокументирована и направлена на соблюдение следующих принципов: «Служебная необходимость». - Только операторам (конечным пользователям и администраторам), которым постоянно требуется доступ к зоне безопасности, разрешено иметь учетные записи в этой зоне. - Полномочия присваиваются только оператору с подтвержденной необходимостью знания (например, настройка системы гарантирует, что операторы имеют доступ только к информации, файлам и системным ресурсам, необходимым для их определенных задач). Доступ к другим системным функциям отключен. «Минимум полномочий». - Настройка системы гарантирует, что права пользователя и администратора контролируются таким образом, чтобы все выданные им полномочия соответствовали индивидуальным потребностям. - Учетные записи гарантируют только полномочия, необходимые для обычной, повседневной работы. Дополнительные полномочия предоставляются только на временной основе. «Разграничение обязанностей» и «Четыре глаза». - Документально оформленное руководство по разделению ролей находит отражение в специализированной документации разработчика. - Ключевые обязанности разделены. Это означает, что некоторые роли не могут выполняться одним и тем же лицом, например: - роли для отправки и подтверждения транзакций; - роли администратора приложений и офицера безопасности; - роли администратора сети и администратора операционной системы.			

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
	- Ключевые разрешения разделяются, чтобы обеспечить соблюдение принципа четырех глаз. Это требование применяется как минимум к действиям по управлению доступом и настройке безопасности для следующих компонентов: интерфейс обмена сообщениями и коммуникационный интерфейс, модули HSM, сервис SWIFTNet Online Operations Manager и защищенный канал. • Контроль и аннулирование учетной записи: - Полномочия немедленно аннулируются, когда сотрудник меняет роли или уходит из организации. - Учетные записи проверяются не реже одного раза в год (в идеале – чаще) и перенастраиваются по мере необходимости для обеспечения соблюдения принципов безопасности доступа. • Экстренная процедура доступа к привилегированным учетным записям документируется и применяется, когда уполномоченные лица недоступны из-за непредвиденных обстоятельств: - Регистрируется любое оперативное использование этой процедуры. - Доступ к привилегированным учетным записям из-за непредвиденных обстоятельств, контролируется. Их использование регистрируется, а пароль изменяется после экстренного использования.	●	●

5.2. Управление токенами

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Обеспечить надлежащее управление, отслеживание и использование подключенных аппаратных токенов аутентификации (если используются токены). Компоненты, входящие в область применения - Подключенные аппаратные токены аутентификации, используемые для операций SWIFT. - Устройства для ввода ПИН-кода (PED), используемое для эксплуатации HSM. Факторы риска - Кража токенов аутентификации. - Отсутствие отслеживаемости событий. - Неправильно применяется управление HSM.			
Руководство по применению Суть ЭК Подключенные аппаратные токены аутентификации управляются надлежащим образом во время назначения, распространения, отзыва, использования и хранения. Контекст ЭК Защита подключенных аппаратных токенов аутентификации имеет важное значение для защиты соответствующей учетной записи оператора или системы и соответствует передовому опыту в области обеспечения безопасности, обеспечивая дополнительный уровень защиты от злоумышленников. Рекомендации по внедрению - Управляемый процесс применяется для назначения и распределения подключенных аппаратных токенов, используемых для операций SWIFT (например, USB-токен, HSM-токен, смарт-карта). - Назначение токена проверяется не реже одного раза в год (в идеале – чаще). - Аппаратные токены личного назначения аннулируются, когда физическому лицу больше не нужен доступ, и при этом они по возможности должны быть уничтожены (отозваны и ликвидированы). - Ведется запись о владении назначенными аппаратными токенами. - Аппаратные токены физически удаляются из системы и защищаются или контролируются, когда они не используются. - Когда используется удаленное устройство для ввода ПИН-кода (PED), применяются следующие практики по обеспечению безопасности: - PED-ключи должны сохраняться и быть доступными только для соответствующего персонала (оригиналы и копии следует хранить в сейфе, а доступ должен отслеживаться). - Потоки к HSM должны быть защищены согласно руководству по Alliance Security, согласно которому требуется ограничить программное обеспечение, развернутое на удаленном ПК. Такой ПК должен представлять собой выделенный ПК оператора, а не стандартный ПК оператора общего назначения.			

5.3А. Процесс проверки персонала

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
Цель ЭК. Обеспечить благонадежность персонала, работающего в локальной среде SWIFT, путем проведения его проверки. Компоненты, входящие в область применения - Все сотрудники, контрагенты и персонал с доступом к связанным со SWIFT системам. Факторы риска - Неблагонадежный персонал или системные операторы.			
Руководство по применению Суть ЭК Персонал, работающий с локальной инфраструктурой SWIFT, проверяется до начала работы в этой роли и периодически после этого. Контекст ЭК Процесс проверки персонала, как штатного, так и внештатного, обеспечивает дополнительную гарантию того, что конечные пользователи или администраторы локальной инфраструктуры SWIFT заслуживают доверия, и это снижает риск внутренних угроз. Рекомендации по внедрению В той мере, насколько это разрешено действующими законами и нормативно-правовыми актами, и в той мере, насколько доступна информация, рекомендуются нижеприведенные руководящие принципы и соответствующие проверки: - Весь персонал, находящийся в рамках области применения, проверяется не реже одного раза в пять лет. - Процесс проверки персонала при первоначальном приеме на работу в идеале включает следующие виды контроля: - установление личности, - подтверждение всей информации о квалификации, - подтверждение прежней истории занятости, - проверка сведений о любых прошлых или имеющихся гражданских или уголовных разбирательствах в отношении сотрудника, - оценка любого участия в стороннем бизнесе, которое может привести к конфликту интересов, - проверка кредитной истории. - Периодический процесс проверки включает следующие виды активностей: - проверка сведений о любых имеющихся гражданских или уголовных разбирательствах в отношении сотрудника, - оценка любого участия в стороннем бизнесе, которое может привести к конфликту интересов, - проверка кредитной истории.			

5.4. Физическое и логическое хранение паролей

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Защитить физически и логически записанные пароли. Компоненты, входящие в область применения Учетные записи и пароли, определенные для следующих компонентов: • ПК оператора (или промежуточный сервер): операционная система. • ПК оператора (или промежуточный сервер): интерактивный сеанс пользователя. • Зона безопасности: все приложения, операционные системы, HSM и связанные токены и сетевые компоненты. • Сервис SWIFTNet Online Operations Manager и pecypc swift.com. Факторы риска • Кража паролей.			
Руководство по применению Суть ЭК Любые записанные пароли для привилегированных учетных записей хранятся в защищенном физическом или логическом месте, доступ к которому ограничен по принципу служебной необходимости. Контекст ЭК Безопасное хранение записанных паролей (репозиторий) гарантирует, что пароли не будут легко доступны для окружающих, тем самым защищая их от обычной кражи. Данный ЭК охватывает хранение паролей экстренного доступа, привилегированных паролей, а также любых других паролей учетных записей. Рекомендации по внедрению • Пароли, записанные на физическом носителе, защищены посредством: - размещения внутри запечатанного, защищенного от вскрытия конверта, - хранения в сертифицированном сейфе (например, сертифицированные компанией Underwriters Laboratories (UL) сейфы класса TL или EN-1143-1), - регистрации доступа к хранилищу и доступа к паролю учетной записи. • Пароли, хранящиеся логически (в цифровой форме), защищены посредством: - шифрования в состоянии покоя или обфускации (то есть пароли не хранятся в формате обычного текста), - аутентифицированный доступ к месту хранения, в идеальном случае с ведением журнала доступа. • Пароли не записываются в руководствах пользователя или других рабочих материалах, кроме тех случаев, когда пароль хранится в соответствии с вышеприведенными указаниями. • Если оператору, обычно не имеющему доступ, предоставляется экстренный доступ, пароль изменяется сразу же после завершения экстренного сеанса, а также при необходимости изменяется комбинация для доступа в сейфовое хранилище. • Пароли не встроены в скрипты или в другой программный код.			

6. Обнаружение аномальной активности в системах или журналах транзакций

6.1. Защита от вредоносных программ

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Обеспечить защиту локальной инфраструктуры SWIFT от вредоносных программ. Компоненты, входящие в область применения • ПК оператора (или промежуточный сервер) – операционные системы Windows. • Зона безопасности: связанные со SWIFT сервером – операционные системы Windows. Факторы риска • Выполнение вредоносного кода. • Использование известных уязвимостей системы безопасности.			
Руководство по применению Суть ЭК Установлено программное обеспечение для защиты от вредоносных программ от заслуживающего доверия разработчика, и оно постоянно обновляется на всех системах. Контекст ЭК Вредоносная программа – это общий термин, который включает в себя множество типов навязчивого и нежелательного программного обеспечения, включая вирусы. Технология защиты от вредоносных программ (более широкий термин, чем антивирус) эффективна для защиты от вредоносного кода, который имеет известный цифровой или поведенческий профиль. Рекомендации по внедрению • Сканирование «на лету» на наличие вредоносных программ (также известное как сканирование в режиме реального времени или в фоновом режиме) выполняется во всех системах из области применения. По требованию полное сканирование проводится по крайней мере еженедельно для серверов и ежедневно для ПК оператора. Чтобы не снижалась производительность, полное сканирование выполняется во время низкой загрузки и (или) вне рабочего времени. • В область сканирования следует включать все файлы систем, находящихся в области применения. Исключение элементов или каталогов из сканирования подлежит оценке с точки зрения рисков с учетом настроек пользовательской архитектуры, внутренних требований и политик по безопасности, возможностей продукта и следующих принципов: - Программы (такие как исполняемые файлы, библиотеки, скрипты) и статические данные (такие как файлы конфигураций) следует сканировать при обращении к ним или при их установке, а также регулярно после этого, в дополнение к механизму обеспечения целостности среды выполнения (в соответствии с проверкой целостности программного обеспечения, описанной в ЭК 6.2), предполагающего идентификацию изменений или неожиданных дополнений файлов. - Содержимое сервера базы данных (файлы с данными) могут быть исключены из области сканирования в том случае, если эти данные были проверены перед размещением в базе данных. • Программное обеспечение для защиты от вредоносных программ от заслуживающего доверия разработчика устанавливается на всех компьютерных платформах и обновляется в соответствии с частотой сканирования. • Обнаружены и исправлены системы, у которых не срабатывает обновление профилей или запуск запланированных сканирований. • Программное обеспечение для защиты от вредоносных программ проверено на совместимость с операционной средой. • Программное обеспечение для защиты от вредоносных программ настроено в режиме предотвращения, если это возможно, после оценки влияния на работу. Рекомендуется настроить программное обеспечение для защиты от вредоносных программ так, чтобы подозрительные файлы не удалялись, а			

помещались в карантин с одновременным оповещением об этом службы по безопасности организации. Это позволит службе безопасности проводить расследования по таким оповещениям и в будущем, возможно, предотвращать «ложноположительные срабатывания», позволяя при этом восстанавливать файлы в случае подтверждения их подлинности.

- Убедитесь в том, что передача любого содержимого файла не содержит никаких видов вирусов или других данных, которые могут создать риски для отправителя, SWIFT или получателя.

Дополнительные улучшения

- Системы защиты от вредоносных программ используют комбинацию сигнатурных и эвристических методов обнаружения.
- Решения для защиты от вредоносных программ внедряются в системы, отличные от Windows.

6.2. Целостность программного обеспечения

Тип ЭК: обязательный	Применяется к архитектуре:	A 	B
Цель ЭК. Обеспечить целостность программного обеспечения приложений, связанных со SWIFT. Компоненты, входящие в область применения • Зона безопасности: коннектор. • Зона безопасности: графический интерфейс пользователя для обмена сообщениями и коммуникационного интерфейса. • Зона безопасности: приложение интерфейса обмена сообщениями. • Зона безопасности: приложение коммуникационного интерфейса. • Зона безопасности: RMA. • Зона безопасности: SNL. Факторы риска • Несанкционированные изменения системы.			
Руководство по применению Суть ЭК Регулярно выполняется проверка целостности программного обеспечения в интерфейсе обмена сообщениями, коммуникационном интерфейсе и других связанных со SWIFT приложениях. Контекст ЭК Проверки целостности программного обеспечения обеспечивают контроль обнаружения неожиданной модификации операционного программного обеспечения. Рекомендации по внедрению • Проверки на целостность программного обеспечения во всех компонентах из области применения проводятся при включении и еще по крайней мере один раз в день. Варианты реализации: - интегрированы в продукт, - программные решения по мониторингу целостности файлов (FIM) от сторонних разработчиков. • Проверка целостности загружаемого программного обеспечения осуществляется посредством проверки контрольной суммы во время его развертывания. Дополнительные улучшения • Проверка целостности выполняется в памяти. • Проверка целостности выполняется на уровне операционной системы. • Системы в зоне безопасности реализуют белый список приложений на операционной системе, что позволяет исполнять только известные и достоверные приложения.			

6.3. Целостность базы данных

Тип ЭК: обязательный	Применяется к архитектуре:	A	B
Цель ЭК. Обеспечить целостность записей базы данных для интерфейса обмена сообщениями SWIFT. Компоненты, входящие в область применения - Базы данных для продуктов интерфейса обмена сообщениями. Примечание. это требование не относится к Архитектуре А3, которая не имеет интерфейса обмена сообщениями в пользовательской среде. Факторы риска - Нарушение целостности конфиденциальной информации.			
Руководство по применению Суть ЭК Регулярно выполняется проверка целостности в базах данных, которые записывают транзакции SWIFT. Контекст ЭК Проверка целостности базы данных обеспечивает контроль обнаружения непредвиденной модификации записей, хранящихся в базе данных. Рекомендации по внедрению - Функциональность проверки целостности базы данных включена для обеспечения целостности на уровне записи (проверяется контрольная сумма или подписи записей) и подтверждения того, что нет пробелов в последовательной нумерации транзакций. Варианты реализации: - Интегрирована в приложение интерфейса обмена сообщениями. - Интегрирована в систему управления базами данных. Дополнительные улучшения - Полная проверка целостности базы данных выполняется регулярно, в идеале – каждые две недели. - Проверка целостности включает в себя полную проверку ссылок всех записей (например, отсутствие «висячих» записей между таблицами) и поиск любых неожиданно удаленных записей. - Выделенный экземпляр базы данных используется для целей SWIFT.			

6.4. Ведение журнала операций и мониторинг

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Записывать события в системе безопасности и обнаруживать аномальные действия и операции в локальной среде SWIFT. Компоненты, входящие в область применения • Уровень обмена данными: сеть. • ПК оператора (или промежуточный сервер): операционная система. • Зона безопасности: коннектор. • Зона безопасности: графический интерфейс пользователя для обмена сообщениями и коммуникационного интерфейса. • Зона безопасности: все серверные приложения и операционные системы. • Зона безопасности: сеть и HSM. • Зона безопасности: база данных. Факторы риска • Отсутствие отслеживаемости событий. • Нераспознанные аномалии или подозрительная активность.			
Руководство по применению Суть ЭК Внедрены средства обнаружения аномальной активности, а также процесс или инструмент для регулярной записи и просмотра журналов операций. Контекст ЭК Разработка плана ведения журнала и мониторинга является основой для эффективного обнаружения аномального поведения и потенциальных атак. Чем сложнее операционная среда, тем больше будут необходимы средства ведения журнала и мониторинга для надлежащего обнаружения. Упрощение операционной среды позволит упростить и ведение журнала, и мониторинг. Рекомендации по внедрению • Общие цели ведения журнала и мониторинга: - Внедрить план ведения журнала операций, относящихся к безопасности, и настроить выдачу аварийных сигналов для подозрительных событий безопасности (когда это поддерживается приложением). - Внедрить план мониторинга событий безопасности в журналах операций и мониторинга других данных (например, бизнес-операций в режиме реального времени через графический интерфейс) и установить план реагирования на аварийные сигналы. • Вся деятельность по ведению журнала и мониторингу соответствует действующим законам и нормативно-правовым актам, условиям трудовых договоров, которые превалируют над любым руководством по применению. • Ведение журнала: - Реализованы средства по ведению журнала операций для обнаружения аномальной активности в зоне безопасности, а также любых попыток подорвать эффективность ЭК в зоне безопасности. - Журналы обеспечивают возможность отслеживать использование учетной записи соответствующим лицом.			

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
	- Контрольные журналы операций приложений коммуникационного интерфейса и интерфейса обмена сообщениями хранятся не менее 12 месяцев и в достаточной степени защищены от компрометации на уровне администратора предприятия (например, файлы журнала передаются в отдельную систему с отличающимися учетными данными системного администратора). - Журналы операций операторов ПК, файервола и базы данных хранятся не менее 31 дня. - Ведутся как минимум следующие журналы операций: - o История командной строки для привилегированных учетных записей операционных систем на серверах. - o Журналы приложений коммуникационного интерфейса и интерфейса обмена сообщениями и журналы операционной системы, которые содержат аномальное поведение системы (например, активность за пределами обычного рабочего времени, несколько неудачных попыток входа в систему, ошибки аутентификации, изменения в пользовательских группах). - o Журналы файервола. - o Журналы баз данных (если доступны и как минимум в случае размещенных решений по базам данных). • Мониторинг: - Существуют процедуры для выявления подозрительных попыток входа в любую привилегированную учетную запись операционной системы или приложения. - Существуют процессы мониторинга для проверки данных мониторинга серверов, приложений и баз данных, которую ежедневно выполняет человек, либо проверка выполняется посредством автоматического мониторинга с оповещением. - Существуют процессы мониторинга для регулярной проверки данных мониторинга сети. - О необычной или подозрительной активности сообщается соответствующей команде службы безопасности для дальнейшего проведения расследования. Дополнительные улучшения • Реализуется возможность централизованного ведения журнала, что сводит к минимуму количество мест ведения журналов, подлежащих проверке. • Запись сеанса реализована для записи всех действий, выполняемых привилегированными учетными записями на серверах зоны безопасности SWIFT.	●	●

6.5A. Обнаружение вторжений

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
Цель ЭК. Обнаруживать и предотвращать аномальную сетевую активность, направленную на локальную среду SWIFT, и внутри нее. Компоненты, входящие в область применения - Сеть (уровень обмена данными и внутри зоны безопасности). Факторы риска - Нераспознанные аномалии или подозрительная активность.			
Руководство по применению Суть ЭК Обнаружение вторжений используется для обнаружения несанкционированного доступа к сети и аномальной активности. Контекст ЭК Системы обнаружения вторжений чаще всего внедряются в сети, устанавливая базовую линию для обычных операций и отправляя уведомления при обнаружении аномальной активности в сети. Чем сложнее операционная сеть (например, системы, связывающиеся со многими пунктами назначения, доступ в Интернет), тем более необходимыми будут средства обнаружения вторжений для надлежащего обнаружения. Поэтому упрощение поведения сети позволит применять более простые и эффективные решения обнаружения вторжений. Системы обнаружения вторжений часто сочетают сигнатурные и поведенческие методы обнаружения. Некоторые системы имеют возможность реагировать на любые обнаруженные вторжения (например, прекращение соединения). Рекомендации по внедрению - Система обнаружения вторжений настроена на обнаружение аномальной активности внутри зоны безопасности и на ее границе. - Активность сети, отслеживаемая для анализа обнаружения вторжений, может включать: - входящие и исходящие подключения в нерабочее время, - непредусмотренные передачи файлов из зоны безопасности, - непредусмотренное использование порта или протокола (например, P2P). - Система имеет повторяющийся процесс для регулярного обновления известных сигнатур вторжения. - Если обнаружено вторжение, раздается сигнал тревоги, и защитный механизм запускается вручную или автоматически, если это позволяет инструмент. - Обнаружение вторжений осуществляется через стандартный процесс реагирования на инциденты. Дополнительное улучшение - Системы обнаружения вторжений имеют возможность проверять зашифрованные потоки.			

7. План реагирования на инциденты и информирования

7.1. Планирование реагирования на киберинциденты

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Обеспечить последовательный и эффективный метод управления киберинцидентами. Компоненты, входящие в область применения - Организационный контроль. Факторы риска - Избыточный ущерб от недостаточной готовности к киберинцидентам.			
Руководство по применению Суть ЭК Пользователь имеет адекватный и проверенный план реагирования на киберинциденты. Контекст ЭК Доступность и соответствующая устойчивость имеют ключевое значение для бизнеса. В этой связи разработка и тестирование плана реагирования на киберинциденты является весьма эффективным способом снижения степени воздействия и продолжительности воздействия реального киберинцидента. Так как опыт накапливается либо при проверке плана, либо во время реальных инцидентов, важно использовать полученный опыт для совершенствования этого плана. Кроме того, планирование информирования об угрозах и инцидентах имеет решающее значение для оказания помощи финансовому сообществу в осуществлении эффективной защиты от кибератак. Рекомендации по внедрению - Пользователь разработал и ежегодно обновляет план реагирования на киберинциденты. Существует официальный план резервного копирования и восстановления для всех важнейших бизнес-направлений для поддержки активностей реагирования на инциденты. - План реагирования на киберинциденты включает в себя актуальные контактные данные (внутренние и внешние) и таймеры эскалации. Такой план должен учитывать: - Киберинциденты по безопасности - Дорожная карта по восстановлению (Cyber Security Incident - Recovery roadmap), которая представляет собой неисчерпывающий список шагов или действий, которые пользователь должен выполнить в случае нарушения кибербезопасности и обратиться в службу поддержки SWIFT (SWIFT Support). Подробности изложены в Бюллетене по SWIFT-ISAC №10047. - При планировании реагирования на киберинциденты необходимо соблюдать и учитывать внутренние политики, правопорядок и правила безопасности в пределах юрисдикции пользователя. - План пересматривается как минимум ежегодно и как минимум каждые два года тестируется, обеспечивая тем самым безопасное восстановление важных бизнес-операций с минимальным временем простоя после инцидента в сфере кибербезопасности. - План реагирования на киберинциденты включает в себя следующие действия: - незамедлительно уведомить соответствующие внутренние и внешние заинтересованные стороны и высшее руководство, - незамедлительно уведомить соответствующие внешние заинтересованные организации (как правило, это регулятор(ы), надзорные органы, правоохранительные органы), - незамедлительно уведомить Центр поддержки клиентов SWIFT по каналу по умолчанию и выполнить другие обязательства, применимые к пользователям в случае инцидента по безопасности, включая обязательство сотрудничать и предоставлять судебные материалы, которые могут потребоваться SWIFT, - оперативно локализовать затронутую систему путем идентификации и ограничения распространения			

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
атаки, - привлечь квалифицированных специалистов по кибербезопасности к выявлению и рассмотрению киберинцидента. Ответственность за принятие своевременных корректирующих мер по максимально быстрому проведению расследования, устранению последствий для всей инфраструктуры и возобновлению безопасных операций несет пользователь, - проанализировать корректность текущих данных самоаттестации и, как это указано в Политике обеспечения безопасности пользователей SWIFT, аннулировать такую аттестацию и предоставить новые данные аттестации, - произвести анализ ситуации после обработки инцидента для выявления и устранения уязвимостей, - полностью оформить инцидент документально. • Пользователь располагает задокументированным планом по своевременному обмену информацией об угрозах с организациями, осуществляющими обмен разведданными, правоохрательными/местными органами регулирования (в соответствии с требованиями, предъявляемыми в юрисдикции каждого пользователя) и SWIFT. Обмен информацией об угрозах потенциально может способствовать анализу основных причин и обмену анонимными показателями нарушения нормального функционирования системы безопасности (Indicators of Compromises – IOC) с сообществом. • Предназначенная к распространению информация об инциденте сначала оценивается на предмет соблюдения действующих законов и нормативно-правовых актов (например, о защите персональных данных, о конфиденциальности исследований) и обеспечения защиты от непреднамеренного обмена конфиденциальной информацией или данными, не относящимися к инциденту. • Пользователь располагает возможностью для обработки сводок об угрозах безопасности, распространяемых SWIFT, например, в форме показателей нарушения нормального функционирования системы безопасности (IOC). У пользователя установлены процедуры для: - обеспечения распространения информации среди соответствующих лиц внутри организации, - блокировки входящего/исходящего трафика по IP-адресам/адресам URL, указанным в показателях нарушения нормального функционирования системы безопасности (IOC).			

7.2. Информирование и обучение в сфере безопасности

Тип ЭК: обязательный	Применяется к архитектуре:	А	В
Цель ЭК. Убедиться в том, что весь персонал осведомлен о и исполняет свои обязательства по обеспечению безопасности путем проведения регулярных мероприятий по обучению, безопасности и информированию. Компоненты, входящие в область применения - Все сотрудники, контрагенты и персонал с доступом к системам SWIFT (использование, обслуживание или администрирование). Факторы риска - Повышенная угроза безопасности со стороны ненадлежащим образом обученного персонала.			
Руководство по применению Суть ЭК Для всех сотрудников проводятся ежегодные мероприятия по информированию о безопасности, включая специализированный тренинг по SWIFT-ролям с привилегированным доступом. Контекст ЭК Программа обучения и информирования по вопросам безопасности поощряет сознательное и надлежащее поведение сотрудников и администраторов по обеспечению безопасности и в целом вносит вклад в передовой опыт в области обеспечения безопасности. Кроме того, особенно важно, чтобы пользователи с привилегированным доступом имели соответствующие знания и опыт. Рекомендации по внедрению - Ежегодные мероприятия по информированию и обучению персонала по безопасности, которые могут в себя включать: - Обучение по продуктам и сервисам SWIFT (например, через интерактивную обучающую платформу SWIFTSmart, которая доступна всем пользователям). - Информирование об угрозах кибербезопасности в сфере финансовых услуг или в отношении ролей и обязанностей персонала. - Защита и управление паролями. - Защита устройств. - Информирование о поведении в рамках исполнения служебных обязанностей, которое способствует обеспечению безопасности (например, идентификация нежелательной почты (спам) и фишинг-мошенничества, загрузка файлов, практика поиска и просмотра информации в Web). - Предоставление отчетов о подозрительных событиях и видах активности. - Обнаружение и реагирование на киберинциденты в соответствии с планом реагирования, принятым в организации. - Внутренняя или внешняя программа, которая дополнительно позволяет сотрудникам получать и продлевать сертификаты. - Обучение осуществляется наиболее удобным способом, в том числе с использованием компьютеров, в классах, в рамках вебинаров. - Лица, имеющие доступ к приложениям SWIFT, данным, сертификатам, сетям и т. д., обладают достаточным уровнем знаний и осведомлены о соответствующих киберрисках (например, через показатели IOC, публикуемые SWIFT), наилучших видах практики поведения и процессах.			

7.3А. Тест на проникновение

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
Цель ЭК. Проверить готовность конфигурации безопасности и определить пробелы в безопасности путем выполнения испытаний на возможность проникновения в систему. Компоненты, входящие в область применения • ПК оператора (или промежуточный сервер): все аппаратное и программное обеспечение и сеть. • Уровень обмена данными. • Зона безопасности: все аппаратное и программное обеспечение и сетевые компоненты (за исключением специальных приложений SWIFT и централизованных SWIFT сервисов, таких, как SWIFTNet InterAct, FileAct FIN, SWIFTNet Instant or WebAccess). Факторы риска • Неизвестные уязвимости системы безопасности или ошибки в конфигурациях системы безопасности.			
Руководство по применению Суть ЭК Испытание возможности проникновения в приложения, узлы систем и сети осуществляется внутри и в пределах зоны безопасности и ПК операторов. Контекст ЭК Испытание возможности проникновения в систему основано на смоделированных атаках, которые используют технологии, сходные с теми, что используются и в реальных атаках. Данное решение используется для определения методов и способов, которыми могут воспользоваться злоумышленники, а также степени вмешательства, на которую они могут быть способны для доступа к выбранной для атаки среде. Проведение этих смоделированных атак является эффективным средством выявления слабых мест в среде, которая может потребовать корректировки, усовершенствования или дополнительных средств контроля. Рекомендации по внедрению • Организация использует подход, основанный на оценке рисков, для определения наиболее вероятной области для атаки (например, зоны безопасности или конкретного сервера, включая другие возможные сервисы, поддерживающие зону безопасности), метода (например, тест белого ящика, тест черного ящика) и источника атаки (например, внутренняя, внутри или вне зоны безопасности, или внешняя атака) для проведения теста. • Испытание возможности проникновения проводится как минимум каждые 2 года, а также после значительных изменений в среде (например, замена сервера или сетевых устройств на новые, изменения сетевой структуры). • Испытание возможности проникновения тщательно планируется и выполняется таким образом, чтобы избежать возможного влияния на доступность или целостность. • Испытание возможности проникновения выполняется высококвалифицированным персоналом, независимым от команды, отвечающей за инфраструктуру SWIFT (силами внутренней "красной команды" или с привлечением внешних ресурсов) • Испытание возможности проникновения в сетевые компоненты и узлы (например, проверка баз правил и конфигураций) выполняется в сервисной производственной среде. • Имеются достаточные меры предосторожности, чтобы свести к минимуму любое операционное воздействие от проведения испытания возможности проникновения в систему. • Результаты испытания возможности проникновения в систему задокументированы (с ограниченным доступом) и используются в качестве входных данных для процесса обновления в области обеспечения безопасности. Примечание. Ожидается, что этот ЭК станет обязательным в следующей версии документа.			

Дополнительное улучшение

- Испытание возможности проникновения в систему выполняется специальными приложениями SWIFT при соблюдении [Политики тестирования пользователей SWIFT](#). Это специальное приложение выполняется в среде тестирования, чтобы избежать потенциального воздействия на доступность или целостность.

7.4А. Оценка рисков на основе сценариев

Тип ЭК: рекомендуемый	Применяется к архитектуре:	А	В
Цель ЭК. Оценить риск и готовность организации на основе сценариев вероятных кибератак. Компоненты, входящие в область применения - Организационный контроль (люди, процессы и инфраструктура). Факторы риска - Избыточный ущерб из-за недостаточной готовности к киберинцидентам. - Неопределенная чувствительность к кибервоздействиям.			
Руководство по применению Суть ЭК Регулярно проводится оценка рисков на основе сценариев для повышения готовности реагирования на инциденты и повышения зрелости программы безопасности организации. Контекст ЭК Оценки рисков на основе сценариев учитывают различные типы атак, осуществляемых всеми типами неавторизованных лиц на размещенной инфраструктуре, связанной со SWIFT. Рассматривается следующий неисчерпывающий перечень угроз: имитация конечного пользователя, несанкционированное изменение сообщений, перехват сообщений, слабые места программного обеспечения сторонних производителей, компрометация систем или атаки типа "отказ в обслуживании" (DoS), влияющие на доступность служб. Результаты оценки и существующие меры по снижению рисков помогают определить области рисков, которые могут потребовать дальнейших действий, снижения рисков или обновления плана реагирования на киберинциденты. О выявленных действиях, мерах по смягчению последствий или обновлениях необходимо сообщать и отслеживать их выполнение с учетом их критичности в соответствии с процессом управления рисками информационной безопасности (Information Security Risk Management – ISRM). Существует несколько концепций ISRM и с ними можно ознакомиться (например, на сайтах, посвященных NIST, ENISA, COBRA или ISO, или в локальном стандарте или стандарте регулятора, или наборе ЭК с таким же уровнем защиты, который предусматривает отраслевое руководство) для того, чтобы определить подходящие процесс ISRM и ресурсы пользователя (такие как критические элементы контроля безопасности корпоративной информационной системы (CIS)). Эти концепции могут быть использованы для того, чтобы начать реализовывать базовый процесс управления рисками, который будет в дальнейшем совершенствоваться для обеспечения возможности реагирования на специфические риски пользователя. Рекомендации по внедрению - Сценарий оценки рисков и планирования активности проводится для: - идентификации возможных методов злоумышленников, которые они применяют для получения несанкционированного доступа к локальной инфраструктуре SWIFT, основанных на экспериментальных или вероятных технических приемах, вытекающих из побудительных мотивов и возможностей злоумышленников, - анализа эффективности существующих мер профилактики и обнаружения с целью смягчения ожидаемых технических приемов злоумышленников, которые они применяют для получения несанкционированного доступа к среде, - анализа вероятности и степени воздействия значимых и возможных векторов атак с учетом существующих средств контроля, - анализа эффективности существующих средств реагирования для ограничения воздействия значимых и возможных векторов атак с учетом существующих средств контроля, - определения необходимости в дополнительных предупреждающих или обнаруживающих средствах контроля. - Деятельность по оценке и планированию осуществляется не реже одного раза в год и обновляется с учетом проводимых мероприятий по управлению рисками, когда происходят значительные технологические изменения или когда аналитика угроз указывает на соответствующие изменения			

побудительных мотивов и возможностей злоумышленников.

- Текущая аналитика угроз и наблюдаемые/вероятные атаки (вектора, технические приемы, участники и т. д.) используются в качестве основы для подходящих сценариев.
- Каждый класс ресурсов (устройства конечного пользователя, серверы, сетевые устройства) оценивается на подверженность угрозам безопасности на регулярной основе, а также при изменениях или выявлении новых угроз.

Приложение А. Сводная матрица по факторам риска

Приведенная ниже матрица представляет собой сводную информацию по факторам риска, упоминаемым в данном документе, в которой элементы контроля безопасности сопоставляются с документированными рисками, которые они помогают минимизировать.

Элементы контроля безопасности SWIFT	1.1	1.2	1.3A	2.1	2.2	2.3	2.4A	2.5A	2.6	2.7	2.8A	2.9A	2.10A	3.1	4.1	4.2	5.1	5.2	5.3A	5.4	6.1	6.2	6.3	6.4	6.5A	7.1	7.2	7.3A	7.4A
Факторы риска																													
Кража токенов аутентификации																		X											
Ведение бизнеса с несанкционированным контрагентом												X																	
Компрометация системы аутентификации организации	X		X																										
Компрометация достоверных резервных данных								X																					
Компрометация учетных данных пользователя	X		X																										
Воспроизведение учетных данных	X		X													X													
Удаление журналов операций и следов преступлений		X																											
Избыточное количество потенциальных векторов атак						X							X																
Избыточный ущерб из-за недостаточной готовности к киберинцидентам																										X			X
Излишние полномочия или доступ		X															X												
Выполнение вредоносного кода																					X								
Использование небезопасной конфигурации системы						X							X																
Использование известных уязвимостей системы безопасности					X					X											X								
Незащищенность от интернет-атак	X		X																										
Подверженность нестандартным методам обеспечения безопасности											X																		
Повышенная угроза безопасности со стороны ненадлежащим образом обученного персонала																											X		

Элементы контроля безопасности SWIFT	1.1	1.2	1.3A	2.1	2.2	2.3	2.4A	2.5A	2.6	2.7	2.8A	2.9A	2.10A	3.1	4.1	4.2	5.1	5.2	5.3A	5.4	6.1	6.2	6.3	6.4	6.5A	7.1	7.2	7.3A	7.4A
Факторы риска																													
Отсутствие отслеживаемости событий		X												X				X						X					
Нарушение операционной конфиденциальности									X																				
Нарушение операционной целостности									X																				
Нарушение конфиденциальности ключевых данных				X			X	X																					
Нарушение целостности конфиденциальной информации				X			X																X						
Взлом, подбор или другая компьютерная компрометация паролей															X	X													
Кража паролей																X				X									
Нарушения в разграничении обязанностей																	X												
Несанкционированный доступ	X			X													X												
Несанкционированный физический доступ														X															
Несанкционированные изменения системы		X																				X							
Неаутентифицированный системный трафик				X			X																						
Неконтролируемое разрастание систем и данных				X																									
Нераспознанные аномалии или подозрительная активность												X												X	X				
Неопределенная чувствительность к кибервоздействиям																													X
Неизвестные уязвимости системы безопасности или ошибки в конфигурациях системы безопасности																												X	
Неблагонадежный персонал или системные операторы																			X										

Приложение Б. Примеры зон безопасности для разных архитектур

Следующие диаграммы предназначены только для справки и описывают один из многих способов проектирования зоны безопасности для каждой архитектуры (A1, A2, A3, B).

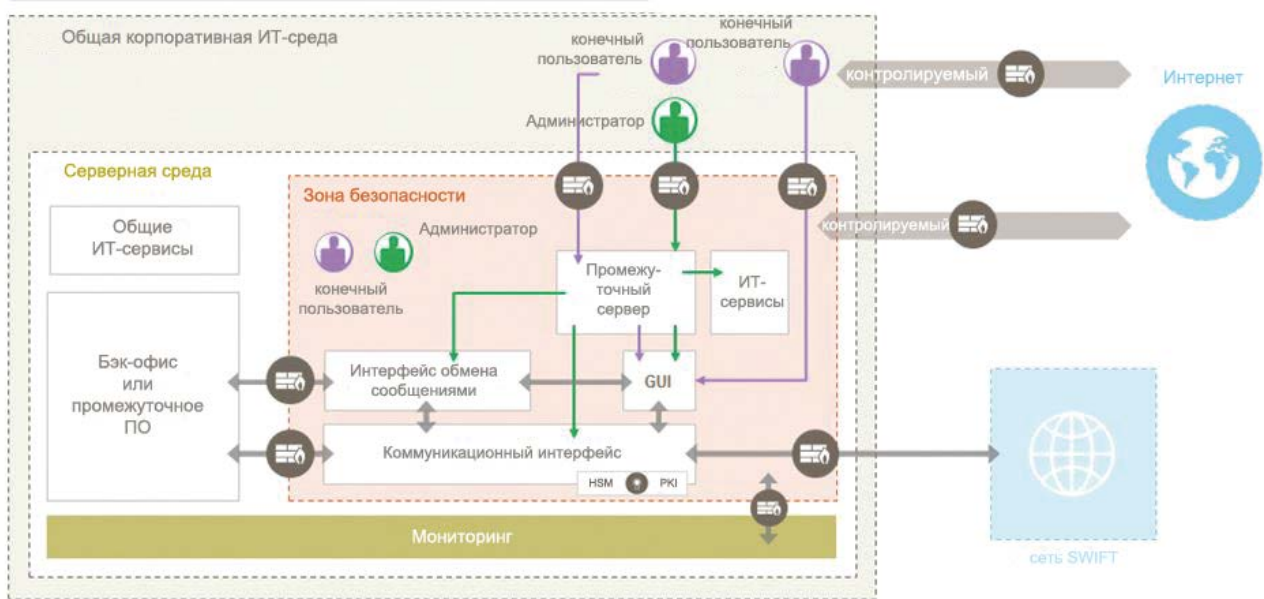


Рисунок 7. Пример зоны безопасности для Архитектуры A1.
Полное размещение на стороне клиента

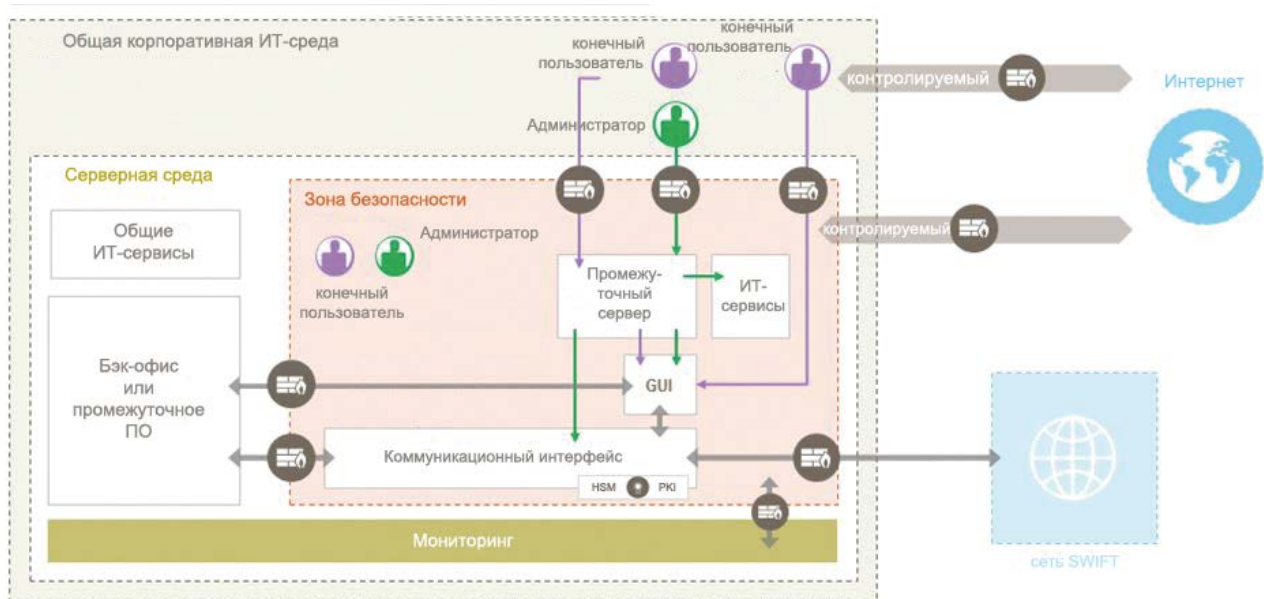


Рисунок 7б. Пример зоны безопасности для Архитектуры A1.

Коммуникационный интерфейс на стороне клиента

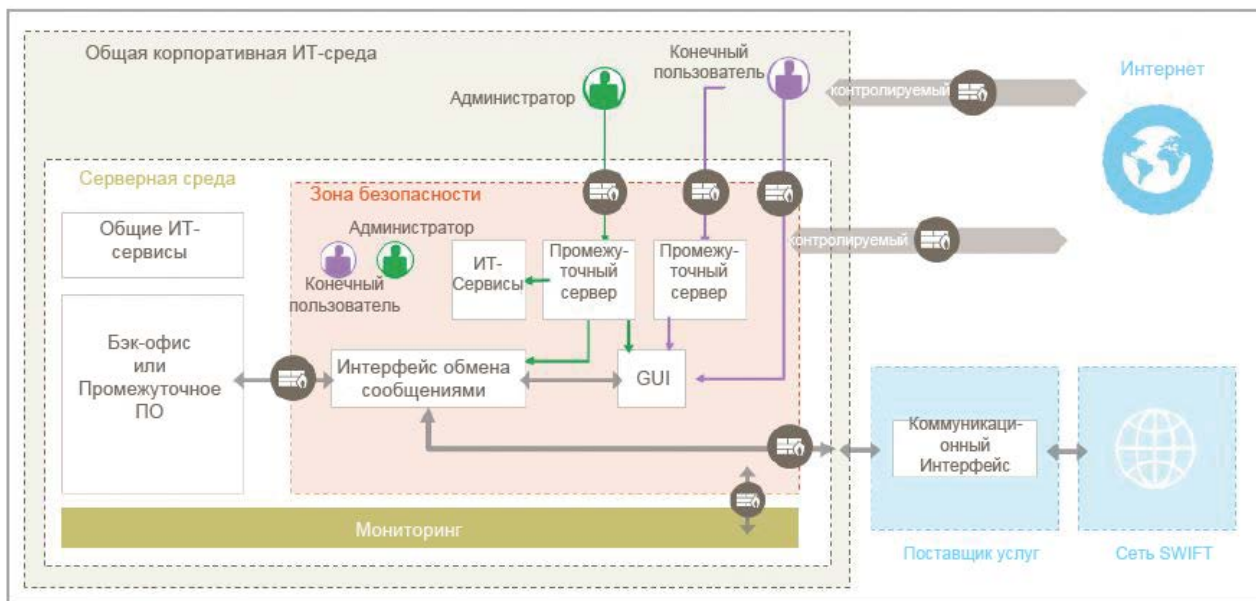


Рисунок 8. Пример зоны безопасности для Архитектуры А2. Частичное размещение на стороне клиента

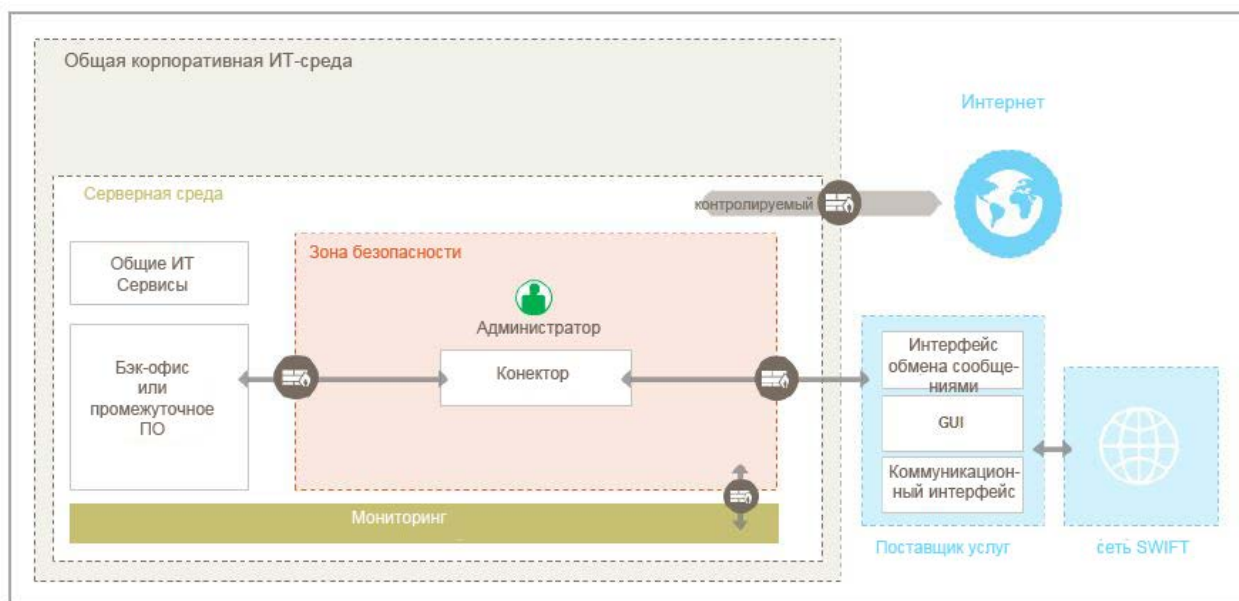


Рисунок 9. Пример зоны безопасности для Архитектуры А3. С использованием коннектора

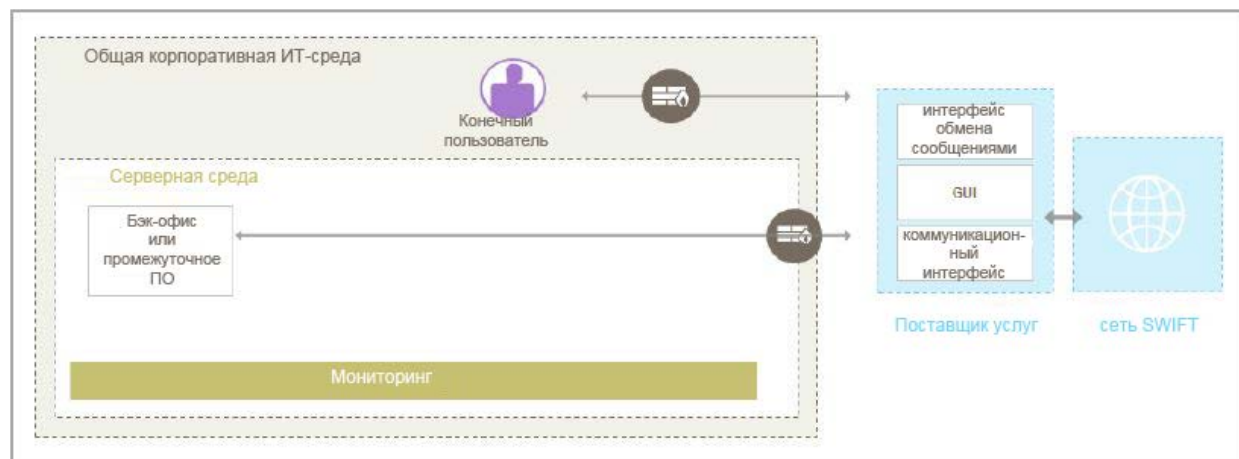


Рисунок 10. Архитектуры В. Без собственной инфраструктуры

Приложение В. Примеры сценариев угроз

Следующие сценарии представляют собой наглядные примеры, которые помогают пользователям понять типы киберугроз и то, как каждый элемент контроля безопасности (ЭК) способствует их минимизации. Эти сценарии не являются исчерпывающими и предназначены только для формирования контекста и образовательных целей. Вероятность и влияние каждого сценария могут существенно различаться в зависимости от показателей среды пользователя.

1.1. Обеспечение защиты среды SWIFT

- Злоумышленники компрометируют учетные данные системного администратора корпоративной службы каталогов Active Directory, что позволяет злоумышленникам получить доступ ко всем учетным данным, хранящимся в каталоге.
- Злоумышленники подвергают опасности поддерживаемую ИТ-инфраструктуру (например, сервер сканирования, сервер исправлений), расположенной в общей ИТ-среде, для кражи системных учетных данных и последующего доступа к локальной инфраструктуре SWIFT.
- Злоумышленники получают административный доступ к ПК оператора, что позволяет получить доступ к локальной базе данных учетных записей и повторно использовать сохраненные хэш-коды для доступа к другим системам.
- Оператор щелкает на вредоносную ссылку в сообщении электронной почты, неумышленно загружая вредоносные программы, которые наносят ущерб локальному компьютеру.

1.2. Контроль за привилегированными учетными записями операционной системы

- Системный администратор, использующий корневую учетную запись в Linux, выполняет несанкционированные действия (например, изменяет конфигурации безопасности, преднамеренно вызывает отказ системы), которые не отслеживаются отдельным оператором.
- Оператор с излишними административными полномочиями удаляет журналы и другие доказательства для скрытия несанкционированных действий.

1.3А. Защита платформы виртуализации

- Злоумышленник с доступом к гипервизору может нарушить конфиденциальность, целостность и доступность виртуальных машин, на которых работают сервисы SWIFT.
- Злоумышленник с доступом к функциям конфигурирования гипервизора или виртуальной машины может создать новые виртуальные машины для совершения атак в дальнейшем, например, путем создания фальшивых сервисов приложений, чтобы спровоцировать пользователей разгласить конфиденциальную информацию или скачать вредоносную программу.
- Уязвимости и/или незащищенные конфигурации на виртуальной платформе могут позволить злоумышленникам нарушить разграничение между доменами виртуальных машин.

2.1. Безопасность внутреннего потока данных

- Злоумышленник, имеющий сетевой доступ к зоне безопасности, нарушает целостность транзакций, переданных между интерфейсом обмена сообщениями и коммуникационным интерфейсом.
- Злоумышленник, имеющий сетевой доступ к зоне безопасности, может наблюдать за незашифрованным трафиком между локальными компонентами SWIFT и записывать конфиденциальные транзакции.

2.2. Обновления для системы безопасности

- Злоумышленник использует известную и неустраненную уязвимость, чтобы получить доступ к серверу, на котором размещено связанное со SWIFT приложение.
- Операционная система выходит за рамки жизненного цикла поддержки, осуществляемой разработчиком, что приводит к постоянным открытым уязвимостям, для которых отсутствуют исправления от разработчика.

2.3. Повышение надежности системы

- Для доступа к интерфейсу администрирования сетевого файервола злоумышленник использует имя пользователя и пароль по умолчанию.

- Злоумышленник использует уязвимость, связанную с неиспользуемым сетевым протоколом (например, telnet), чтобы получить доступ к серверу SWIFT.

2.4А. Безопасность потока данных в бэк-офисе

- Злоумышленник, расположенный между бэк-офисом и интерфейсом обмена сообщениями, проводит неаутентифицированные транзакции.
- Злоумышленник создает атаку типа «незаконный посредник», чтобы изменить расчетные счета получателей действующих транзакций SWIFT.
- Злоумышленник, расположенный между бэк-офисом и интерфейсом обмена сообщениями, может отслеживать незашифрованный трафик и записывать конфиденциальные транзакции.

2.5А. Защита данных при передаче во внешнюю среду

- Местоположение резервных копий данных скомпрометировано, в результате чего незашифрованные резервные копии SWIFT и хеш-коды учетных данных становятся доступны, предоставляя злоумышленнику возможность получить ценную информацию об операторах SWIFT и типичной активности в локальной среде.
- Незашифрованные резервные копии данных серверов SWIFT передаются по небезопасному сетевому подключению, что приводит к тому, что злоумышленник получает доступ с правом считывания информации ко всем последним записям трафика сообщений.

2.6. Конфиденциальность и целостность сессии оператора

- Оператор, оставив свой рабочий стол и не осуществив отложенную блокировку экрана, позволяет неавторизованному пользователю получить доступ к учетной записи оператора и интерфейсу обмена сообщениями SWIFT.
- Злоумышленник может осуществлять наблюдение за незашифрованной сессией оператора и изучать незашифрованную информацию для планирования будущей атаки.
- Злоумышленник может осуществлять наблюдение за незашифрованной сессией оператора и украсть учетные данные для создания мошеннической транзакции SWIFT.
- Злоумышленник перехватывает транзакцию, отправленную между браузером и веб-приложением, изменяет ее содержимое и пересылает его веб-приложению.
- Злоумышленник может перехватить открытую сессию или обойти схему аутентификации по причине небезопасных настроек с целью захватить или создать мошенническую транзакцию SWIFT.

2.7. Сканирование на уязвимость системы

- Обнаруженная уязвимость остается неопределенной и необработанной, что позволяет злоумышленнику воспользоваться уязвимостью для получения доступа к серверу, связанному со SWIFT.

2.8А. Аутсорсинг критически важных видов деятельности

- Аутсорсинговый провайдер не проводит надлежащего отделения систем SWIFT от других систем с низкой степенью защиты, что приводит к распространению вируса во всех средах и нарушению целостности систем SWIFT.
- Аутсорсинговый провайдер не обеспечивает надлежащего контроля доступа, в результате чего неуполномоченный сотрудник получает доступ к интерфейсу обмена сообщениями SWIFT.

2.9А. Средства контроля транзакционного бизнеса

- Взаимоотношения в рамках RMA не контролируются должным образом, что приводит к обработке транзакции от непроверенного контрагента.
- Ежедневная сверка данных не выполняется, в результате чего мошенническая транзакция остается незамеченной до истечения даты расчетов.
- Транзакции не ограничиваются обычными рабочими часами, что приводит к незамеченной мошеннической транзакции.

2.10А. Повышение надежности приложений

- Учетные записи или пароли по умолчанию могут быть использованы злоумышленниками для

получения несанкционированного доступа к приложениям.

- Чрезмерные привилегии, назначенные пользователям приложений, могут стать объектом злонамеренного использования для выполнения несанкционированных действий в приложениях.
- Злоумышленники используют уязвимости, связанные с неиспользуемыми сетевыми протоколами (например, протокол telnet) или функциями, предоставляемыми ненужными пакетами программ, для получения доступа к серверу SWIFT

3.1. Физическая защита

- Ненадлежащее ведение журнала операций приводит к отсутствию возможности основательного расследования того, у каких сотрудников был физический доступ к сейфу после обнаружения пропажи набора HSM-токенов SWIFT.
- Недостаточно строгий контроль за доступом к центру сбора и обработки данных позволяет неуполномоченному персоналу с физическим доступом осуществлять физические атаки на SWIFT сервера.

4.1. Политика паролей

- Политика паролей устанавливается, но не применяется, что приводит к тому, что операторы используют ненадежные пароли, которые легко взламываются во время кибератаки.
- Пароль недостаточной длины ведет к получению ненадежного хеш-кода пароля, который злоумышленник похищает из памяти компьютера, что позволяет ему восстановить исходный пароль.
- Одни и те же пароли используются администратором для систем внутри и за пределами зоны безопасности, в результате чего злоумышленник взламывает более уязвимый пароль и повторно его использует, чтобы получить доступ к зоне безопасности.

4.2. Многофакторная аутентификация

- Многофакторная аутентификация не реализована для доступа к приложениям, в результате чего злоумышленник использует украденный пароль, чтобы получить полный доступ к интерфейсу обмена сообщениями SWIFT.
- Многофакторная аутентификация не реализована для доступа к операционной системе интерфейса обмена сообщениями, в результате чего злоумышленник использует украденный пароль, чтобы получить полный административный доступ к системе.

5.1. Логический контроль доступа

- Контроль принципа «минимум полномочий» не осуществляется, что позволяет оператору, которому требуется только доступ для чтения, создавать и отправлять транзакции SWIFT.
- Средства контроля по разграничению обязанностей не применяются, что позволяет одному оператору создавать и одобрять транзакцию SWIFT, противоречащую политике пользователя по утверждению транзакций.
- Доступ к учетной записи не аннулируется своевременно, в результате чего недавно переведенный сотрудник использует свой остаточный доступ для изменения записей в интерфейсе обмена сообщениями SWIFT.

5.2. Управление токенами

- Ненадлежащее ведение записей при назначении подключенных аппаратных токенов приводит к невозможности аннулировать правильные токены после ухода сотрудников из организации, что ведет к неизвестному и неконтролируемому остаточному доступу.
- Токен остается вставленным в ПК оператора, когда он не используется, позволяя злоумышленнику использовать токен в качестве подтверждения аутентификации в рамках осуществления атаки.

5.3А. Процесс проверки персонала

- Новый сотрудник, ранее судимый за финансовое мошенничество, не проверяется до того, как ему предоставляется доступ оператора, в результате чего неблагонадежное лицо получает ответственную должность.
- Действующие сотрудники не проверяются на регулярной основе, в результате чего организация не располагает информацией о сотруднике, который работал неполный рабочий день в другом

финансовом учреждении и в настоящий момент имеет значительный конфликт интересов.

5.4. Физическое и логическое хранение паролей

- Оператор SWIFT хранит свои пароли на листе бумаги на своем рабочем месте, позволяя любому персоналу, имеющему физический доступ к этому месту, просматривать записанный пароль.
- Администратор приложения SWIFT хранит свои административные пароли в текстовом файле на своем ПК, что позволяет любому системному администратору получить доступ к паролям.

6.1. Защита от вредоносных программ

- На ПК оператора не установлено программное обеспечение для защиты от вредоносных программ, в результате чего обычный вредоносный файл может подвергнуть компьютер риску заражения после щелчка по фишинговому электронному сообщению.
- Программное обеспечение для защиты от вредоносных программ, установленное на серверах SWIFT, не обновляется регулярно в результате чего может быть не обнаружено вредоносное программное обеспечение, наносящее вред серверам.

6.2. Целостность программного обеспечения

- Продвинутой злоумышленник изменяет исполняемую программу интерфейса обмена сообщениями, и это не обнаруживается, поскольку проверка целостности программного обеспечения не была реализована.
- Вредоносная версия обновления программного обеспечения устанавливается из-за непроверенной контрольной суммы во время ее загрузки.

6.3. Целостность базы данных

- Отсутствие проверки целостности базы данных позволяет специализированной вредоносной программе удалять записи базы данных при выполнении несанкционированных транзакций.
- Отсутствие проверки целостности базы данных позволяет злоумышленнику изменять записи базы данных, чтобы скрыть следы преступлений.
- Отсутствие проверки целостности базы данных может привести к тому, что пробелы в последовательности нумерации записей не будут выявлены.

6.4. Ведение журнала операций и мониторинг

- Ненадлежащее системное протоколирование приводит к невозможности отслеживать вредоносные привилегированные команды конкретного лица во время расследования киберинцидента.
- Журналы операций ведутся, но их мониторинг не осуществляется, что приводит к тому, что аномальная активность остается незамеченной до тех пор, пока не будет нанесен значительный финансовый ущерб.

6.5A. Обнаружение вторжений

- Отсутствие возможностей обнаружения вторжений приводит к тому, что необычный трафик за пределами обычных рабочих часов остается незамеченным.
- Отсутствие возможностей обнаружения вторжений приводит к непредвиденному протоколу обмена информацией для заданного порта, который остается незамеченным.
- Система обнаружения вторжений не сконфигурирована должным образом или не осуществляется ее мониторинг, в результате чего вторжения, которые могли бы быть обнаружены, скрыты множеством ложных срабатываний.

7.1. Планирование реагирования на киберинциденты

- Непротестированный план реагирования на киберинциденты приводит к ненадлежащему и нескоординированному реагированию на серьезное кибервторжение, что приводит к значительному и неизбежному финансовому ущербу.
- Неисправность в системе уведомлений SWIFT во время киберинцидента приводит к неполному информированию, что приводит к аналогичным киберинцидентам в других учреждениях, которых можно было бы избежать.
- Неспособность действовать на основе аналитики угроз ведет к кибервторжениям с

использованием известных методов, которых можно было бы избежать.

7.2. Информирование и обучение в сфере безопасности

- Операторы SWIFT не проходят обучение на основе передового опыта в области обеспечения безопасности, в результате чего сотрудники открывают вредоносные фишинговые сообщения электронной почты.
- Администраторы приложений SWIFT не проходят обучение по вопросам безопасности, связанным с их ролью, и поэтому не обнаруживают подозрительную активность в системах SWIFT или не сообщают о ней.
- Сотрудникам службы безопасности SWIFT не хватает знаний, связанных с их ролью, и поэтому они не присваивают должным образом права операторам, в результате принцип разграничения обязанностей игнорируется.

7.3А. Тест на проникновение

- Тест на проникновение в среду SWIFT не проводится, и поэтому чрезмерно разрешающие правила файервола не обнаружены и не исправлены.
- Тест на проникновение проводят неквалифицированные сотрудники, которые не могут имитировать типичного злоумышленника из финансовой индустрии, что приводит к ложному чувству безопасности и недостаточной мотивации проводить улучшения в области безопасности.

7.4А. Оценка рисков на основе сценариев

- Реалистичные сценарии рисков не тестируются внутри организации, что приводит к неправильной оценке вероятности, воздействия и общего киберриска.
- Сценарии риска тестируются без вовлечения бизнес-подразделений и соответствующих руководителей, что приводит к некорректной общей оценке деятельности и недостаточной мотивации проводить улучшения в области безопасности.

Приложение Г. Словарь терминов

Термин	Определение
Принцип четырех глаз	Принцип безопасности, в соответствии с которым два отдельных лица должны одобрить действие, прежде чем оно может быть совершено. Этот принцип также известен как «правило двойного контроля» или принцип выдачи разрешения или полномочий только при согласии на это двух лиц.
Администратор	Может относиться: к администраторам приложений, отвечающим за настройку, поддержку, и осуществление привилегированных действий через интерфейс приложений; системным администраторам, ответственным за настройку, поддержку и осуществление других привилегированных действий через операционные системы или другой прямой (не через пользовательский интерфейс) доступ.
Учетная запись приложения	Учетные записи приложений определяются как процедуры входа, предназначенные для приложения. Они не предназначены для использования человеком или для входа через графический интерфейс. Учетные записи приложений имеют пароль, который хранится, извлекается и используется приложением автоматически. Учетные записи приложения обычно используются для целей интеграции (например, вызова API) или для поддержки STP (сквозной обработки данных).
Класс ресурсов	Категория вычислительных ресурсов (например, базы данных, серверы, приложения).
Бэк-офис	Системы, отвечающие за бизнес-логику, генерацию транзакций и другие действия, происходящие до передачи в локальную инфраструктуру SWIFT.
Коннектор	Коннекторы – это локальное программное обеспечение, предназначенное для упрощения взаимодействия с интерфейсом обмена сообщениями или коммуникационным интерфейсом или же с тем и с другим. При использовании коннектора компоненты интерфейса предлагаются поставщиком услуг (например, сервис-бюро, инфраструктурой хабов или SWIFT). Alliance Lite2 AutoClient, Direct Link, решения для передачи файлов и аналогичные продукты считаются коннекторными решениями.
CVSS – общая оценка уязвимости системы	CVSS – Common Vulnerability Scoring System – является открытым отраслевым стандартом для оценки степени опасности уязвимостей программного обеспечения путем присвоения баллов этим степеням опасности, позволяя устанавливать приоритеты для выбора соответствующих способов реагирования и необходимых ресурсов в соответствии с угрозой.
Коммуникационный интерфейс	Коммуникационный интерфейс – это программное обеспечение, обеспечивающее связь между сетью SWIFTNet и другим программным обеспечением – интерфейсом обмена сообщениями. Коммуникационные интерфейсы обеспечивают централизованную, автоматизированную и высокопроизводительную интеграцию с различными внутренними финансовыми приложениями и интерфейсами конкретных сервисов. Коммуникационные интерфейсы предоставляются SWIFT (например, Alliance Gateway или Alliance Gate Instant) и сертифицированными сторонними разработчиками.
Инцидент кибербезопасности	Любое вредоносное действие или подозрительное событие, которое наносит ущерб или пытается нанести ущерб компьютерной среде.
Уровень обмена данными	Передача данных между бэк-офисом (или уровнем промежуточного ПО) и локальной инфраструктурой SWIFT.

Термин	Определение
Выделенный ПК оператора	ПК оператора, расположенный в зоне безопасности и предназначенный для взаимодействия с компонентами зоны безопасности.
Конечный пользователь	Лица, которым требуется интерактивный доступ к приложению (например, для бизнес-транзакций, мониторинга и контроля доступа). Сюда входят сотрудники службы безопасности и администраторы приложений, ответственные за их настройку и поддержку.
Общая (корпоративная) ИТ-среда	Общая ИТ-инфраструктура используется для поддержки целой организации. Сюда входят общие ИТ-сервисы и ПК оператора общего назначения.
Общие ИТ-сервисы	Сервисы поддержки ИТ-инфраструктуры, такие как сервисы аутентификации, управление ресурсами, базы данных, хранение данных, сервисы безопасности (например, установка исправлений) и сетевые сервисы (например, DNS, NTP).
ПК оператора общего назначения	ПК оператора, расположенный в общей корпоративной среде и используемый для повседневной деловой активности.
Графический интерфейс пользователя (GUI)	GUI – Graphical user interface – программное обеспечение, которое формирует графический интерфейс для пользователя (то есть Alliance Web Platform и аналогичные продукты).
Аппаратный токен	USB-токен, смарт-карта или аналогичное устройство.
Интерактивный вход в систему/сессию	Сеансовая модель, которая показывает обмен данными (например, когда пользователь вводит данные или команду, а система возвращает данные обратно).
Показатели компрометации (IOC)	IOC – Indicators of compromise – признаки, которые могут быть замечены в сети или операционной системе и которые могут указывать на нарушение нормального функционирования системы безопасности.
ИТ-сервисы	Набор компонентов для поддержки бизнес-процессов внутри зоны безопасности, таких как платформа развертывания релизов и установки исправлений, служба каталогов Active Directory.
Промежуточный сервер	Сервер, используемые для предоставления пользователю доступа к зоне безопасности из корпоративной сети (например, Citrix или «удаленный рабочий стол» – Remote Desktop).
Локальная аутентификация	Локальная аутентификация (английская аббревиатура LAU от «Local Authentication») обеспечивает целостность и проверку подлинности файлов, обмен которыми осуществляется между приложениями. Локальная аутентификация требует, чтобы отправитель и получатель использовали один и тот же ключ для вычисления подписи для локальной аутентификации файла.
Локальная инфраструктура SWIFT	Коллекция или набор специфических компонентов SWIFT внутри рабочей среды пользователя, включая системы, приложения, поддерживающее аппаратное обеспечение, токены и другие аутентификаторы.
Интерфейс обмена сообщениями	Интерфейсное программное обеспечение для обмена сообщениями, поддерживающее использование сервисов обмена сообщениями SWIFT (сервисы FIN, InterAct и FileAct). Это программное обеспечение предоставляет пользователям возможность подключать бизнес-приложения к сервисам обмена сообщениями SWIFT и, как правило, подключается непосредственно к коммуникационному интерфейсу. Интерфейс обмена сообщениями предоставляется SWIFT (например, Alliance Access или Alliance Messaging Hub) и сертифицированными сторонними разработчиками.
Промежуточное ПО	Программное обеспечение, которое позволяет двум отдельным программам взаимодействовать друг с другом (например, IBM® MQ, BizTalk).

Термин	Определение
Многофакторная аутентификация	Многофакторная аутентификация – это такой метод аутентификации, при котором требуется по меньшей мере два различных фактора для проверки подлинности пользователя. Могут быть выбраны следующие факторы аутентификации: - фактор знаний (что-то, что знает пользователь), например ПИН-код или пароль; - фактор владения (что-то, что имеет пользователь), например HSM-токен, Digipass, мобильный телефон или RSA-устройство для ввода одноразового пароля; - человеческий фактор (что-то, что является доказательством пользователя), например отпечаток пальца или любая другая биометрия.
Список управления доступом к сети (ACL)	ACL – Access Control List – список управления доступом к сети относится к правилам, применяемым к номерам портов или IP-адресам для контроля входящего и исходящего трафика. Эти списки доступны на сетевом устройстве.
Сетевые устройства	Компоненты, используемые для управления, маршрутизации и обеспечения безопасности сети (например, маршрутизаторы, коммутаторы, файерволы).
Учетные записи операционной системы (ОС)	Учетные записи пользователей на сервере или ПК, которые используются для прямого доступа к операционной системе.
Оператор	Имеет отношение к следующим двум отдельным терминам: Конечные пользователи – лица, которым требуется интерактивный доступ к приложению (например, для бизнес-транзакций, мониторинга и контроля доступа). Сюда входят сотрудники службы безопасности и администраторы приложений, ответственные за их настройку и поддержку. Администраторы операционной системы – ответственные за настройку, обслуживание и выполнение других привилегированных действий в операционных системах, поддерживающих локальную инфраструктуру SWIFT.
ПК оператора	Персональный компьютер, используемый операторами для выполнения своих обязанностей.
ПИН (PIN)	PIN – Personal Identification Number – персональный идентификационный номер – Секретный номер, который выполняет функцию пароля, предотвращая несанкционированный доступ других лиц к использованию токена, мобильного устройства или карты.
Привилегированная учетная запись	Учетная запись в операционной системе или приложении, предоставляющая дополнительные права доступа, недоступные обычному пользователю. Включает в себя учетные записи администраторов в операционных системах, а также учетные записи сотрудников безопасности или владельцев приложений в приложениях.
Сервис по управлению взаимоотношениями (RMA)	RMA – Relationship Management Application – фильтр, который позволяет пользователю ограничивать корреспондентов, от которых могут быть получены сообщения, а также тип сообщений, которые могут быть получены. Использование механизма RMA является обязательным для сервиса FIN. Он доступен на рекомендуемой основе для SCORE FileAct и Generic FileAct.
Удаленный доступ	Доступ к компьютеру извне, то есть за пределами локальной сети. Например, из дома или из сети другой организации.
Удаленный вход в систему	Вход в систему, инициированный через сетевое соединение, а не напрямую с локального ПК.
Зона безопасности	Сегментированная зона на территориях пользователей, отделенная от всего предприятия. Зона безопасности содержит системы, связанные с SWIFT (например, интерфейс обмена сообщениями, коммуникационный интерфейс), и дополнительно другие защищенные системы.
Серверная среда	Центр обработки и хранения данных или другие хостинг-серверы с защищенным физическим местоположением.

Термин	Определение
Сервис-бюро	Сервис-бюро – организация, являющаяся или не являющаяся пользователем SWIFT, которая предоставляет услуги по подключению пользователей к SWIFT. Услуги, предлагаемые сервис-бюро, обычно включают в себя предоставление на условиях совместного использования, размещение или обеспечение функционирования компонентов, используемых для подключения к SWIFT, а также предоставление доступа, управление сессиями и безопасностью от имени пользователей SWIFT. Сервис-бюро подпадают под действие Программы совместного использования инфраструктуры (Shared Infrastructure Programme).
Поставщик услуг	Организация, предоставляющая услуги пользователям SWIFT в отношении обеспечения повседневной работы SWIFT-соединения. Оказываемые услуги обычно включают в себя распределение или использование компонентов подключения SWIFT, обеспечение входа в систему или управление сеансами или безопасностью для пользователей SWIFT. К этим организациям относятся поставщики инфраструктур с совместным доступом (например, сервис-бюро, поставщики коллективных схем подключений, Lite2 for Business Applications, Alliance Lite2, Alliance Remote Gateway, групповой хаб).
Однопользовательский или безопасный режим	Защищенный режим работы, ограничивающий полномочия пользователя.
Программный токен	Токен аутентификации в логической (программной) форме.
«Толстый клиент»	Программное обеспечение, установленное и выполняемое на локальном ПК оператора, а не через интерфейс браузера.
Третья сторона	Субъект, не зависящий от пользователя SWIFT или поставщика подключения пользователя к SWIFT. Например, привлеченный поставщик ИТ-услуг.
Аутентификационный номер транзакции (TAN)	TAN – Transaction Authentication Number – тип одноразового пароля , который в основном используется одновременно со стандартным ID и паролем. Изначально представлен в виде списка (таблицы).
Безопасность транспортного уровня (TLS)	TLS – Transport Layer Security – криптографический протокол, обеспечивающий конфиденциальность и целостность сети и защиту от атак, основанных на повторе действий.
Пользователь	Организация, которую SWIFT признала в соответствии с Корпоративными правилами как должным образом уполномоченного пользователя сервисов и продуктов SWIFT. Критерии правомочности на то, чтобы стать пользователем SWIFT, изложены в Корпоративных правилах.
Учетные записи пользователей приложений	Учетные записи пользователей, установленные на уровне приложений для предоставления доступа и разрешений к приложениям (то есть неучетным записям операционной системы).

Приложение Д. Сопоставление с отраслевыми стандартами

В таблице ниже элементы контроля безопасности SWIFT сопоставлены со структурами трех международных стандартов по безопасности:

- Национальный институт стандартов и технологий (НИСТ / NIST) – это нерегулятивное Федеральное агентство в министерстве торговли США, которое разработало концепцию кибербезопасности (NIST Cybersecurity Framework), призванную помочь организациям в управлении рисками в сфере кибербезопасности.
- ISO 27002 ISO/IEC 27002 – это стандарт по информационной безопасности, выпущенный международной организацией по стандартизации (ИСО) и Международной электротехнической комиссией (МЭК).
- Стандарт безопасности данных по индустрии платежных карт (PCI DSS) представляет собой частный стандарт по информационной безопасности для организаций, работающих с платежными картами и связанных с ними.

Следующая таблица сопоставления содержит дополнительные сведения о том, как элементы контроля безопасности SWIFT связаны с аналогичными элементами контроля в этих отраслевых стандартах. Если пользователи сертифицированы по какому-либо из этих стандартов и на них распространяется сфера применения этой сертификации, то таблица показывает, как элементы контроля из этих стандартов связаны с элементами контроля безопасности SWIFT.

Для других стандартов SWIFT предлагает использовать справочные материалы, представленные NIST в Приложении А: Базовые принципы Концепции кибербезопасности версии 1.1 («Framework Core» документа «Cybersecurity Framework v1.1») для навигации из таблицы ниже.

Важное примечание

Обратите внимание на то, что соответствие требованиям этих отраслевых стандартов автоматически не подразумевает полного соблюдения элементов контроля безопасности SWIFT. Некоторые аспекты контроля могут не охватываться стандартом. В конечном счете пользователь несет ответственность за оценку достаточности и степени соблюдения одного из этих отраслевых стандартов для оценки соблюдения элементов контроля безопасности SWIFT.

Цель ЭК SWIFT	Концепция кибербезопасности NIST v1.1	ISO 27002 (2013)	PCI DSS 3.2.1
1.1. Обеспечение защиты среды SWIFT Обеспечить защиту пользовательской локальной инфраструктуры SWIFT от потенциально скомпрометированных элементов общей ИТ-среды и внешней среды.	Управление доступом (PR.AC) PR.AC-5: защита целостности сети, включающая в себя разделение на подсети в тех случаях, когда это целесообразно.	Управление безопасностью сети (13.1) 13.1.3: разделение на подсети.	Требование 1: установить и поддерживать конфигурацию файервола для защиты данных владельца карты. Применяемые подразделы: 1.3
1.2. Контроль за привилегированными учетными записями операционной системы Ограничить и контролировать распределение и использование учетных записей операционной системы уровня администратора.	Управление доступом (PR.AC) PR.AC-4: управление правами доступа осуществляется с учетом принципов наименьших привилегий и разделения обязанностей.	Управление доступом пользователей (9.2) 9.2.3: управление правами привилегированного доступа.	Требование 8: осуществлять идентификацию и аутентификацию доступа к компонентам системы. Применяемые подразделы: 8.1, 8.5

Цель ЭК SWIFT	Концепция кибербезопасности NIST v1.1	ISO 27002 (2013)	PCI DSS 3.2.1
1.3A. Защита платформы виртуализации Обеспечить защиту платформы виртуализации и виртуальных машин (ВМ) и соответствующих размещенных компонентов, связанных со SWIFT, на том же уровне, как для физических систем.	Управление доступом (PR.AC) Безопасность данных (PR.DS) Процессы и процедуры защиты информации (PR.IP) Обслуживание (PR.MA) Технология защиты (PR.PT) Все подкатегории	9 Контроль доступа 10 Криптография 11 Физическая защита и защита среды 12 Безопасность операций 13 Безопасность коммуникаций 14 Приобретение, развитие и обслуживание систем	Требование 2: не использовать пароли и другие параметры безопасности систем, установленные разработчиками по умолчанию. Применяемые подразделы: с 2.1 по 2.6
2.1. Безопасность внутреннего потока данных Обеспечить конфиденциальность, целостность и аутентификацию потоков данных между локальными приложениями SWIFT и их связь с ПК оператора.	Безопасность данных (PR.DS) PR.DS-2: данные в процессе передачи защищены.	Передача информации (13.2) 13.2.1: политика и процедуры передачи информации.	Требование 4: шифровать передачу данных владельца карты через открытые, публичные сети. Применяемые подразделы: 4.1
2.2. Обновления для системы безопасности Минимизировать возникновение известных технических уязвимостей в локальной инфраструктуре SWIFT в соответствии с оцененными рисками путем обеспечения поддержки разработчиками, применения обязательных обновлений программного обеспечения и своевременных обновлений для системы безопасности.	Процессы и процедуры защиты информации (PR.IP) PR.IP-12: разработан и внедрен план по управлению уязвимостями. RS.AN-5: установлены процессы фиксации, анализа и реагирования на уязвимости, обнаруженные в организации из внутренних и внешних источников (например, внутренняя проверка, бюллетени по безопасности или исследования в сфере безопасности)	Управление техническими уязвимостями (12.6) 12.6.1: управление техническими уязвимостями.	Требование 6: разрабатывать и поддерживать безопасные системы и приложения. Применяемые подразделы: 6.2
2.3. Повышение надежности системы Уменьшить количество потенциальных векторов кибератак на компоненты, связанные с SWIFT, путем повышения надежности системы.	Процессы и процедуры защиты информации (PR.IP) PR.IP-1: создается и поддерживается базовая конфигурация информационных технологий / промышленных систем управления.	Приобретение, разработка и обслуживание систем (14.1) 14.1.1: анализ и установление требований по информационной безопасности.	Требование 2: не использовать пароли и другие параметры безопасности систем, установленные разработчиками по умолчанию. Применяемые подразделы: 2.2, 2.5
2.4A. Безопасность передачи данных из бэк-офиса Обеспечить конфиденциальность, целостность и взаимную аутентификацию потоков данных между приложениями бэк-офиса (или промежуточного ПО) и подключаемыми компонентами инфраструктуры SWIFT.	Безопасность данных (PR.DS) PR.DS-2: данные в процессе передачи защищены.	Передача информации (13.2) 13.2.1: политика и процедуры передачи информации.	Требование 4: обеспечить шифрование данных держателей карт при их передаче через сети общего пользования. Применяемые подразделы: 4.1

Цель ЭК SWIFT	Концепция кибербезопасности NIST v1.1	ISO 27002 (2013)	PCI DSS 3.2.1
2.5A. Защита данных при передаче во внешнюю среду Защищать конфиденциальность передаваемых данных, связанных со SWIFT и находящихся за пределами зоны безопасности.	Безопасность данных (PR.DS) PR.DS-2: данные в процессе передачи защищены.	Передача информации (13.2) 13.2.1: политика и процедуры передачи информации.	Требование 3: обеспечить безопасное хранение данных держателей карт. Применяемые подразделы: 3.4
2.6. Конфиденциальность и целостность сессии оператора Защищать конфиденциальность и целостность интерактивных сессий оператора, подключающихся к локальной инфраструктуре SWIFT.	Безопасность данных (PR.DS) PR.DS-2: данные в процессе передачи защищены. PR.DS-1: хранимые данные защищены.	Контроль доступа к системе и приложениям (9.4) 9.4.2: безопасные процедуры входа в систему.	Требование 8: осуществлять идентификацию и аутентификацию доступа к компонентам системы. Применяемые подразделы: 8.1
2.7. Сканирование на уязвимость системы Определить известные уязвимости в локальной среде SWIFT путем внедрения регулярного процесса сканирования на уязвимость и принятия мер по результатам сканирования.	Непрерывный мониторинг (DE.CM) DE.CM-8: сканирование уязвимостей выполняется. Оценка рисков (ID.RA) ID.RA-1: выявлены и задокументированы уязвимости ресурсов. RS.AN-5: установлены процессы фиксации, анализа и реагирования на уязвимости, обнаруженные в организации из внутренних и внешних источников (например, внутренняя проверка, бюллетени по безопасности или исследования в сфере безопасности)	Управление технической уязвимостью (12.6) 12.6.1: управление техническими уязвимостями.	Требование 11: регулярное тестирование систем и процессов безопасности. Применяемые подразделы: 11.2
2.8A. Аутсорсинг критически важных видов деятельности Обеспечить защиту локальной инфраструктуры SWIFT от рисков, связанных с передачей на аутсорсинг критически важных видов деятельности.	Бизнес-среда (ID.BE) ID.BE-5: установлены отказоустойчивые требования для поддержания жизнеобеспечения критических сервисов. Управление (ID.GV) ID.GV-2: роли и сферы ответственности в области информационной безопасности координируются и согласовываются с внутрикорпоративными ролями и внешними партнерами. Управление рисками цепочек поставок (ID.SC) С ID.SC1 по ID.SC5	Информационная безопасность в отношениях с поставщиками (15.1) 15.1.1: политика информационной безопасности для взаимоотношений с поставщиками.	Требование 12: проводить политику, направленную на обеспечение информационной безопасности для всего персонала. Применяемые подразделы: 12.8

Цель ЭК SWIFT	Концепция кибербезопасности NIST v1.1	ISO 27002 (2013)	PCI DSS 3.2.1
2.9A. Средства контроля транзакционного бизнеса Ограничить транзакционную активность до проверенных и одобренных контрагентов и в рамках ожидаемых границ обычной деятельности.	Управление доступом (PR.AC) PR.AC-4: управление правами доступа осуществляется с учетом принципов наименьших привилегий и разделения обязанностей.	Передача информации (13.2) 13.2.2: соглашения о передаче информации.	Требование 7: ограничить доступ к данным владельца карты в соответствии со служебной необходимостью. Применяемые подразделы: 7.1.4
2.10A. Повышение надежности приложений Уменьшить количество потенциальных векторов кибератак на компоненты, связанные с SWIFT, путем повышения надежности приложений на сертифицированных SWIFT интерфейсах обмена сообщениями и коммуникационных интерфейсах.	Процессы и процедуры защиты информации (PR.IP) PR.IP-1: создана и ведется базовая конфигурация информационных технологий/систем промышленного контроля	Требования в отношении безопасности информационных систем (14.1) 14.1.1: анализ и уточнение требований обеспечения информационной безопасности	Требование 2: не использовать пароли и другие параметры безопасности систем, установленные разработчиками по умолчанию. Применяемые подразделы: с 2.1 по 2.5 Требование 6: разрабатывать и обслуживать защищенные системы и приложения Применяемые подразделы: 6.2, 6.3, 6.4, 6.5, 6.7
3.1. Физическая защита Предотвратить несанкционированный физический доступ к ключевому оборудованию, рабочим местам, местам размещения оборудования и хранилищам.	Управление доступом (PR.AC) PR.AC-2: физический доступ к ресурсам регулируется и защищен.	Охраняемые зоны (11.1) 11.1.1: физическая безопасность по периметру. 11.1.2: физический контроль входа. 11.1.3: обеспечение защиты офисов, помещений и имущества. 11.1.4: защита от внешних и экологических угроз. 11.1.5: работа в охраняемых зонах.	Требование 9: ограничить физический доступ к данным владельца карты. Применяемые подразделы: 9.1, 9.3, 9.5
4.1. Политика паролей Обеспечить достаточную устойчивость паролей к распространенным паролем атакам путем внедрения и применения эффективной политики паролей.	Управление доступом (PR.AC) PR.AC-1: идентификационные данные и учетные данные контролируются для авторизованных устройств и пользователей.	Управление доступом к системе и приложениям (9.4) 9.4.3: система управления паролями.	Требование 2: не использовать пароли и другие параметры безопасности систем, установленные разработчиками по умолчанию. Применяемые подразделы: 2.1 Требование 8: осуществлять идентификацию и аутентификацию доступа к компонентам системы. Применяемые подразделы: 8.2

Цель ЭК SWIFT	Концепция кибербезопасности NIST v1.1	ISO 27002 (2013)	PCI DSS 3.2.1
4.2. Многофакторная аутентификация Предотвратить ситуацию, когда компрометация одного фактора аутентификации позволяет получить доступ к системам SWIFT, путем реализации многофакторной аутентификации.	Управление доступом (PR.AC) PR.AC-1: идентификационные данные и учетные данные контролируются для авторизованных устройств и пользователей. PR.AC-6: идентификационные данные защищены и привязаны к учетным данным и подтверждаются при взаимодействии PR.AC-7: аутентификация пользователей, устройств и других активов (например, однофакторная, многофакторная) соизмерима с операционным риском (например, рисками безопасности и конфиденциальности отдельных лиц и другими организационными рисками)	Управление доступом к системе и приложениям (9.4) 9.4.2: процедуры безопасного входа в систему.	Требование 8: осуществлять идентификацию и аутентификацию доступа к компонентам системы. Применяемые подразделы: 8.2, 8.3
5.1. Логический контроль доступа Обеспечить соблюдение принципов безопасности: доступ к информации только по служебной необходимости, минимальные полномочия и разграничение обязанностей для учетных записей операторов.	Управление доступом (PR.AC) PR.AC-4: управление правами доступа осуществляется с учетом принципов наименьших привилегий и разделения обязанностей.	Бизнес-требования к управлению доступом (9.1) 9.1.1: политика управления доступом.	Требование 7: ограничить доступ к данным владельца карты в соответствии со служебной необходимостью. Применяемые подразделы: 7.1, 7.2
5.2. Управление токенами Обеспечить надлежащее управление, отслеживание и использование подключенных аппаратных токенов аутентификации (если используются токены).	Управление доступом (PR.AC) PR.AC-1: идентификационные данные и учетные данные контролируются для авторизованных устройств и пользователей.	Ответственность за ресурсы (8.1) 8.1.2: владение ресурсами.	Требование 12: проводить политику, направленную на обеспечение информационной безопасности для всего персонала. Применяемые подразделы: 12.3
5.3A. Процесс проверки персонала Обеспечить благонадежность персонала, работающего в локальной среде SWIFT, путем проведения его проверки.	Процессы и процедуры защиты информации (PR.IP) PR.IP-11: элементы кибербезопасности включены в процессы управления человеческими ресурсами (например, в процессы подготовки кадров, отбор принимаемых на работу лиц).	До начала трудовой деятельности (7.1) 7.1.1: отбор принимаемых на работу лиц.	Требование 12: проводить политику, направленную на обеспечение информационной безопасности для всего персонала. Применяемые подразделы: 12.7
5.4. Физическое и логическое хранение паролей Защитить физически и логически записанные пароли.	Управление доступом (PR.AC) PR.AC-1: идентификационные данные и учетные данные контролируются для авторизованных устройств и пользователей. Безопасность данных (PR.DS) PR.DS-1: хранящиеся данные защищены.	Управление доступом к системе и приложениям (9.4) 9.4.3: система управления паролями.	Требование 8: осуществлять идентификацию и аутентификацию доступа к компонентам системы. Применяемые подразделы: 8.2.1

Цель ЭК SWIFT	Концепция кибербезопасности NIST v1.1	ISO 27002 (2013)	PCI DSS 3.2.1
6.1. Защита от вредоносных программ Обеспечить защиту локальной инфраструктуры SWIFT от вредоносных программ.	Непрерывный мониторинг безопасности (DE.CM) DE.CM-4: вредоносный код обнаруживается.	Защита от вредоносных программ (12.2) 12.2.1: средства контроля от вредоносных программ.	Требование 5: защитить все системы от вредоносных программ и регулярно обновлять антивирусное программное обеспечение или программы. Применяемые подразделы: 5.1, 5.2
6.2. Целостность программного обеспечения Обеспечить целостность программного обеспечения приложений, связанных со SWIFT.	Безопасность данных (PR.DS) PR.DS-6: механизмы проверки целостности используются для проверки программного обеспечения, встроенных программ и целостности информации.	Управление операционным программным обеспечением (12.5) 12.5.1: установка программного обеспечения на операционные системы. Обеспечение безопасности в процессах разработки и сопровождения (14.2) 14.2.4: ограничения на изменения в пакетах программ.	Требование 11: регулярное тестирование систем и процессов безопасности. Применяемые подразделы: 11.5
6.3. Целостность базы данных Обеспечить целостность записей базы данных для интерфейса обмена сообщениями SWIFT.	Безопасность данных (PR.DS) PR.DS-6: механизмы проверки целостности используются для проверки программного обеспечения, встроенных программ и целостности информации.	Управление операционным программным обеспечением (12.5) 12.5.1: установка программного обеспечения на операционные системы. Обеспечение безопасности в процессах разработки и сопровождения (14.2) 14.2.4: ограничения на изменения в пакетах программ.	Требование 11: регулярное тестирование систем и процессов безопасности. Применяемые подразделы: 11.5
6.4. Ведение журнала операций и мониторинг Записывать события в системе безопасности и обнаруживать аномальные действия и операции в локальной среде SWIFT.	Технология защиты (PR.PT) PR.PT-1: записи аудита/журнала операций определены, задокументированы, внедрены и проверяются в соответствии с установленным порядком. Аномалии и события (DE.AE) DE.AE-2: выявленные события анализируются для понимания целей и методов атаки.	Ведение журнала и мониторинг (12.4) 12.4.1: ведение журнала событий.	Требование 10: отслеживать и осуществлять мониторинг любого доступа к сетевым ресурсам и данным владельца карты. Применяемые подразделы: 10.2, 10.6

Цель ЭК SWIFT	Концепция кибербезопасности NIST v1.1	ISO 27002 (2013)	PCI DSS 3.2.1
6.5A. Обнаружение вторжений Обнаруживать и предотвращать аномальную сетевую активность, направленную на локальную среду SWIFT, и внутри нее.	Непрерывный мониторинг безопасности (DE.CM) DE.CM-1: осуществляется мониторинг сети для обнаружения потенциальных событий кибербезопасности.	Управление безопасностью сети (13.1) 13.1.1: сетевые средства контроля.	Требование 11: регулярное тестирование систем и процессов безопасности. Применяемые подразделы: 11.4
7.1. Планирование реагирования на киберинциденты Обеспечить последовательный и эффективный метод управления киберинцидентами.	Процессы и процедуры защиты информации (PR.IP) PR.IP-9: планы реагирования (реагирование на инциденты и непрерывность бизнеса) и планы восстановления (восстановление после инцидентов и аварийное восстановление) имеются в наличии и управляются.	Управление инцидентами и улучшениями в области информационной безопасности (16.1) 16.1.1: обязанности и процедуры.	Требование 12: проводить политику, направленную на обеспечение информационной безопасности для всего персонала. Применяемые подразделы: 12.10
7.2. Информирование и обучение в сфере безопасности Убедиться в том, что весь персонал осведомлен о и исполняет свои обязательства по обеспечению безопасности путем проведения регулярных мероприятий по обучению, безопасности и информированию.	Информированность и профессиональная подготовка (PR.AT) PR.AT-1: все пользователи информируются и обучаются.	Во время трудовой деятельности (7.2) 7.2.2: информирование, обучение и учебно-тренировочные занятия по информационной безопасности.	Требование 12: проводить политику, направленную на обеспечение информационной безопасности для всего персонала. Применяемые подразделы: 12.6
7.3A. Тест на проникновение Проверить готовность конфигурации безопасности и определить пробелы в безопасности путем выполнения испытаний на возможность проникновения в систему.	Процессы и процедуры защиты информации (PR.IP) PR.IP-12: разработан и внедрен план по управлению уязвимостью. Оценка риска (ID.RA) ID.RA-1: выявлены и задокументированы уязвимости ресурсов. RS.AN-5: установлены процессы фиксации, анализа и реагирования на уязвимости, обнаруженные в организации на основе внутренних и внешних источников (например, внутренняя проверка, бюллетени по безопасности или исследования в сфере безопасности)	Анализ информационной безопасности (18.2) 18.2.3: проверка соответствия техническим требованиям.	Требование 11: регулярное тестирование систем и процессов безопасности. Применяемые подразделы: 11.3

Цель ЭК SWIFT	Концепция кибербезопасности NIST v1.1	ISO 27002 (2013)	PCI DSS 3.2.1
7.4A. Оценка рисков на основе сценариев Оценить риск и готовность организации на основе сценариев вероятных кибератак.	Оценка рисков (ID.RA) ID.RA-1: выявлены и задокументированы уязвимости ресурсов. ID.RA-3: выявлены и задокументированы как внутренние, так и внешние угрозы. ID.RA-4: определены степени воздействия и вероятности возникновения бизнес-рисков. ID.RA-5: угрозы, уязвимости, вероятности возникновения и степень воздействия используются для определения риска. ID.RA-6: определены ответы на риски и установлены их приоритеты.	ISO 27001, раздел 8.2	Требование 12: проводить политику, направленную на обеспечение информационной безопасности для всего персонала. Применяемые подразделы: 12.2

Официальное уведомление

Авторские права

SWIFT © 2018. Все права защищены.

Конфиденциальность

В этой публикации содержится конфиденциальная информация SWIFT и третьих сторон, которая может быть раскрыта только вашим сотрудникам, агентам, субподрядчикам или профессиональным советникам (или пользователям SWIFT, которые связаны с вашими аффилированными лицами) на основании «служебной необходимости». Не разглашать информацию, содержащуюся в этой публикации, без предварительного письменного согласия SWIFT.

Перевод

Только английская версия документов SWIFT является официальной и обязательной для исполнения версиями.

Отказ от ответственности

Сведения в этой публикации могут изменяться время от времени. Вы должны всегда обращаться к последней доступной версии.

Торговые марки

«SWIFT» – это торговое наименование компании S.W.I.F.T. SCRL. Логотип SWIFT, «SWIFT», «SWIFTNet», «Sibos», «3SKey», «Innotribe», логотип Standards Forum (Форума стандартов), «MyStandards» и «SWIFT Institute» являются зарегистрированными торговыми марками SWIFT. Другие использованные в этой публикации названия продуктов, сервисов или компаний являются торговыми наименованиями, торговыми марками или зарегистрированными торговыми марками их владельцев.